

O'REILLY®

Blue Team Handbook SOC, SIEM, and Threat Hunting



**Early
Release**

RAW &
UNEDITED

Don Murdoch

Blue Team Handbook: SOC, SIEM, and Threat Hunting

Practical Techniques for Security Operations and
Threat Hunting Teams

With Early Release ebooks, you get books in their earliest form—the author’s raw and unedited content as they write—so you can take advantage of these technologies long before the official release of these titles.

Don Murdoch

O'REILLY®

Blue Team Handbook: SOC, SIEM, and Threat Hunting

by Don Murdoch

Copyright © 2026 Don Murdoch. All rights reserved.

Published by O'Reilly Media, Inc., 141 Stony Circle, Suite 195, Santa Rosa, CA 95401.

O'Reilly books may be purchased for educational, business, or sales promotional use. Online editions are also available for most titles (<https://oreilly.com>). For more information, contact our corporate/institutional sales department: 800-998-9938 or corporate@oreilly.com.

Acquisitions Editor: Simina Calin

Development Editor: Jill Leonard

Production Editor: Kristen Brown

Cover Designer: Susan Brown

Cover Illustrator: José Marzan Jr.

Interior Designer: David Futato

Interior Illustrator: Kate Dullea

June 2026: First Edition

Revision History for the Early Release

- 2026-02-19: First Release

See <https://oreilly.com/catalog/errata.csp?isbn=9798341662292> for release details.

The O'Reilly logo is a registered trademark of O'Reilly Media, Inc. *Blue Team Handbook: SOC, SIEM, and Threat Hunting*, the cover image, and related trade dress are trademarks of O'Reilly Media, Inc.

The views expressed in this work are those of the author and do not represent the publisher's views. While the publisher and the author have used good faith efforts to ensure that the information and instructions contained in this work are accurate, the publisher and the author disclaim all responsibility for errors or omissions, including without limitation responsibility for damages resulting from the use of or reliance on this work. Use of the information and instructions contained in this work is at your own risk. If any code samples or other technology this work contains or describes is subject to open source licenses or the intellectual property rights of others, it is your responsibility to ensure that your use thereof complies with such licenses and/or rights.

979-8-341-66229-2

[LSI]

Brief Table of Contents (*Not Yet Final*)

Preface (available)

Chapter 1: Security Operation Center Field Notes (available)

Chapter 2: SOC Access, Training, Skills, Staffing, and Roles (available)

Chapter 3: Metrics for the SOC (available)

Chapter 4: Threat Hunting Practices in the SOC (unavailable)

Chapter 5: A Day in the Life of a SOC Analyst (unavailable)

Chapter 6: Timekeeping and Event Times (unavailable)

Chapter 7: Continuous Monitoring (unavailable)

Chapter 8: Security Architecture Considerations for SOCs (unavailable)

Chapter 9: SOC and SIEM Use Cases and Template (unavailable)

Chapter 10: Complete SOC and SIEM Use Case Example (unavailable)

Chapter 11: Partial SOC Use Cases (unavailable)

Chapter 12: Detection Engineering (unavailable)

Chapter 13: Security Monitoring Use Cases and Detections by Data Source (unavailable)

Chapter 14: Log Management (unavailable)

Chapter 15: Manual Log Analysis for IR and the SOC (unavailable)

Preface

Blue Team Handbook: SOC, SIEM, and Threat Hunting teaches you how to build out security operations teams and centers as if you were sitting over coffee with a twenty-year veteran in the field. This book was written for the express purpose of providing practical day-to-day guidance for Security Operations, implementing SIEM, and using SIEM and other data sources for modern threat hunting.

This book will cover many topics related to the Security Operations Team from a “Field Notes” perspective. It is based on a long career implementing multiple SIEM technologies, building SOC’s, conducting all manner of cyber investigation, developing and running an MSSP, and working as the Countermeasures lead with one of the largest Splunk installations in the USA. The major topics are:

- Building a Security Operations *functional unit*, including provisioning plan, budget considerations, thought habits, analyst skills, and tiering structures.
- Deciding how to structure your Security Operations capability and the services it will offer.
- An extensive discussion of security focused use cases organized by their respective data source. This chapter describes what to monitor from a given data source, as succinctly as possible. Many of these use cases have a threat hunting theme to them.
- Building Security Operations Use Cases using my own Use Case Template, followed by a complete use case to use as a model in your own work, and some excerpts from other use cases.
- Critical SOC analyst skills and investigation processes, which my own team used while I managed a MSSP operational unit for two years in a mid-sized consulting firm.

- A discussion on applying modern Threat Hunting to the Security Operations team.
- And a host of other topics that relate to security operations, SOC analyst skills, and SIEM.

It is my sincere hope that this book delivers on the Blue Team Handbook motto: “a zero-fluff reference guide for the security practitioner, written with the intention of sharing real life experience”. I trust that you will learn something useful as you read it as many readers of *Blue Team Handbook: Incident Response (BTHb:INRE)* have shared with me over the years.

Who Should Read This Book

This book is for IT professionals, cyber security professionals, security operations staff, security consultants, SOC staff, SIEM designers and consultants, and line managers: those responsible for protecting information assets and teaching the next generation of security professionals.

Why I Wrote This Book

The idea for this book predates the first book in the series, *BTHb: INRE*. In 2011, our team needed to replace our commercial SIEM platform. We headed down a path that led to my fourth major SIEM implementation. We needed an outline to develop use cases, document all the attributes of a use case and SOC procedures to fully use the new platform. I wanted our chosen vendor to have the best possible chance of bidding on the work and completing our use cases on time, and on budget. After vendor selection, we engaged a major firm and set about replacing the legacy platform. The vendor estimated they could achieve 26 to 28 use cases. After 12 weeks, we exceeded project expectations. They implemented 35 of 37 fully defined use cases that totaled 497 pages in print once the paperwork was done. We added fourteen new right click integrations. We even had a custom UI extension that pulled in a dozen account attributes for every user account listed in an alert when we opened an alarm from

three different Active Directory domains. Lastly, we also went from 1.5 people monitoring the prior solution to four full-time analysts because we had so much content and could surface three times the number of security issues and respond appropriately.

Along the way I started an MSSP practice with a good friend working with a consulting firm. We won 78% of our POC's in year one, and had a 100% renewal rate during year two, so several of those life lessons are incorporated herein.

Navigating the Book

Part One: Security Operations Field Notes

- **Chapter 1:** SOC Field Notes: This chapter provides practical advice for setting up a security operations center, proper planning, and definition of SOC services. There are several SIPOC diagrams of several services as well.
- **Chapter 2:** Staff and Maturity. This chapter goes over the various roles in the SOC, analyst training, and traits, and tiering models.
- **Chapter 3:** SOC Metrics. Key metrics and definitions for security operations.
- **Chapter 4:** Threat Hunting. This chapter outlines a threat hunting function in the security operations center.
- **Chapter 5:** SOC Analysis and Investigation. This chapter walks through what an analyst goes through on a daily basis, investigating alerts.
- **Chapter 6:** Timekeeping. There are many issues that SOC analysts can wrestle with when it comes to events and alarm times. This chapter describes many of them.
- **Chapter 7:** Continuous Monitoring. Specific to SOC, this chapter defines how the SOC interacts with and uses data from a continuous monitoring program.

- Chapter 8: Security Architecture and SOC. There are some security architecture topics that impact the SOC and they are covered here.

Part Two: Use Case Development

- Chapter 9: Use Case Template. This chapter defines the Security Operations Use Case template format that the author has used for fifteen years with multiple consulting engagements.
- Chapter 10: Use Case Example. This is a fully developed use case example.
- Chapter 11: Partial SOC Use Cases. This chapter covers some key aspects of some other use case examples.

Part Three: Detections

- Chapter 12: Detection engineering. This is the lifeblood of the SOC, the ability to consume log data and develop alerts and follow through on them.
- Chapter 13: Detections. The longest chapter in the book, this chapter defines numerous detection patterns organized by the type of data they depend on.

Part Four: Log Management

- Chapter 14: Log Management. Log management is a core function of the SOC and one of the key services it provides.
- Chapter 15: Manual Log Review. This section covers some software and command liens to search through log files and covers jq for JSON data.

Acknowledgements

Each of the technical content reviewers throughout the history of *BTHb: SOC, SIEM, and Threat Hunting* is a seasoned InfoSec pro with multiple certifications. This group represents a cross section of the community ranging from security operations and management, vendor product

development and implementation, penetration testing, security engineering, and architecture. These reviewers are directly responsible for 42 pages of additional text from the original draft and collectively provided over 700 suggestions as a testament to their skills and passion for helping me to produce a well written book. I cannot thank them enough. In alphabetical order, the reviewers were:

- **Christopher Beiring:** Lead Security Operations analyst, network penetration tester, and all-around security engineer for a Virginia-based consulting firm.
- **Chris Crowley,** Montance, LLC. Chris is a well-known information security consultant, a Principal Instructor with SANS, and a course author for two courses with the SANS Institute.
- **John Hubbard:** John is a SANS Instructor and author, a SOC Lead for a large pharmaceutical company, and an all-around dedicated blue-teamer.
- **Seth Misener, GSE #28:** Seth is a Cyber Security Expert who serves as a Faculty Fellow with SANS. Seth is a co-author for the bestselling SANS course SEC511: Continuous Monitoring and Security Operations. Seth provided the initial technical review for this book, when it was in its infancy.
- **Ryan O'Connor:** Ryan is an InfoSec security operation engineer for a leading security products company.
- **Phil Plantamura:** Phil is the COO for Security Onion Solutions. Phil has a 20+ year distinguished career in InfoSec working for defense, IR firms, and education.
- **Chris Sanders, GSE #64,** Applied Network Defense. Chris is a well-known security analyst, author, and educator. Chris reviewed the sections titled “A Day in the Life of SOC Analyst” and “Alarm Investigation Process.”
- **Johanna Schafer, M.A.C.E.:** Johanna provided a layperson read through, checked it for readability, grammar, and

punctuation for the first edition of the book during the technical review process. My favorite error she found was the word “bacon” instead of “beacon”, which for some strange reason, was a repeat occurrence in early drafts.

- **Peter Szczepankiewicz:** A long-term colleague and a SANS Instructor.
- **Martin Tremblay, GSE #80:** Martin has 20 years of combined red and blue team experience. He works for a leading international consulting firm and is based in Canada.

Chapter 1. Security Operation Center Field Notes

“If you fail to plan, you plan to fail.”

—Commonly attributed to Benjamin Franklin

“The only thing that is constant is change.”

—Heraclitus

“One of the main cyber-risks is to think they don’t exist. The other is to try to treat all potential risks.”

—Stephane Nappo

A NOTE FOR EARLY RELEASE READERS

With Early Release ebooks, you get books in their earliest form—the author’s raw and unedited content as they write—so you can take advantage of these technologies long before the official release of these titles.

This will be the 1st chapter of the final book.

If you’d like to be actively involved in reviewing and commenting on this draft, please reach out to the editor at jleonard@oreilly.com.

A Security Operations Center (SOC) means different things to different people. Some say they “run the security platform”, others say “they handle incidents”, and still others say, “they monitor the security of the network”. The definition for a SOC used in BTHb:SOCTH is:

“A centralized team in a single organization that monitors the information technology environment for vulnerabilities, unauthorized activity, acceptable use/policy/procedure violations, intrusions into and out of the network, and provides direct support of the cyber incident response process.”

The SOC is the *first line of cyber defense for your organization*. This definition incorporates several important strategies for a successful SOC.

- First, a SOC must be under a single management and reporting structure so that it has a clear line of authority, funding, reporting, and accountability.
- Second, a SOC must have awareness of all aspects of both the business and the IT environment, from the smallest workstation to the largest supercluster in the cloud.
- Third, a SOC needs to understand its area of operation (AO), how they will support the business, monitor business applications, and infrastructure. These criteria must be covered in the SOC charter.
- Fourth, SOC budget needs to be large enough to continually invest in people and support cross training instead of sophisticated software.
- That concept leads to the fifth strategy: train and encourage analysts to be calm, correctly interpret alerts and supporting data. This requires that SOC analysts are well trained.

One point deserves some elaboration. There are few different ways that the SOC team can establish its AO. The SOC can use the IT General Controls program, corporate policy/procedure, guidance from standards like the ISO 2700X series, or follow the Center for Internet Security's 20 critical controls. When designing, building, staffing, and operating a SOC, you need to develop a charter and mission statement.

To achieve these various strategies, the SOC needs to know the network, the application to server relationships, what is happening on the network, and be able to determine if that activity presents a significant enough risk to the organization that the activity needs to be effectively dealt with. SOC teams don't solve security issues with complex SIEM software. They solve it with knowledge, skill, and ability. Complex SIEM tools help – but they are not a technological panacea.

Start With a SOC Charter

Every security operations center needs a “charter”. The SOC charter defines how the SOC serves the business, mandate(s), defines governance and operational rules, what its areas of operation are, and how the organization needs to respond to the investigations conducted by the SOC as it goes about its daily business.

Note that the SOC charter is not the same as a project charter, a document defined by the Project Management Body of Knowledge (PMBOK). The SOC Project Implementation Charter is a formal document that provides an overview, authorizes the project to develop a SOC, the SOC scope and key deliverables, a high-level timeline and milestones, names the key stakeholders, assumptions, constraints, and risks, and empowers the project manager to apply resources and create the SOC. On the heels of the SOC charter usually is a more focused project on implementing the SOC’s key platforms, one or more SIEMs and SOAR suite, and has the same key points plus support for a budget and a brief spending plan.

The SOC charter is often developed in tandem with the SOC/SIEM project implementation charter. The SOC charter should be scoped properly, whereas an implementation charter is a Project Management Institute (PMI) defined document. The term comes from the Project Management Body of Knowledge (PMBOK) as a type “project artifact”. Don’t get the two confused.

Consider, and be Prepared, for Tough Questions

To fund SecOps, SIEM, and a SOC, you will undoubtedly face many questions. Here are a few of them that I have been asked over the years, condensed for publication, quoted to by memory as best as I can. Determine the answer when building your funding request.

- Nothing has happened yet. Why do we need to do this? How can you be sure that nothing has happened yet? As a possible answer, try this out: “It’s not if, it’s when.”

- How will the team detect and respond to security issues, incidents, and data breaches? How did we do this before? Isn't that what the sysadmins do?
- Did the organization incur any costs from an incident last year? Virus outbreaks? What costs are incurred from our peers and competitors?
- How many users at what "level" were negatively affected (as in lost productivity) from an incident?
- How are you going to measure yourselves and get on the IT Balanced Scorecard? As a possible approach, ask if you can be on the *business scorecard during the SOC charter development process*.
- How will the team determine what alarm conditions are prioritized over something else – who wins? (Hint: asset value tied to critical business processes and revenue stream protection).
- I thought we spent X on Security last year. Why do you want more?
- I know we don't have anything worth stealing. Why do we need to do more of this security "stuff"?
- Don't those things cost millions?
- We are doing vulnerability assessments. Isn't that enough? If you are not doing active and timely remediation, then no, it isn't.
- Those security people keep saying no, so I'm going to say no to them this time. So there.
- We can successfully outsource that for 1/8 the cost, right? After all, that's what the vendors say. Why do you disagree with them? Aren't they experts?
- How will this SOC solve business problems for us?

- What does this SOC thing look like in year 1, year 3, and year 5?
- I don't want to buy more expensive security people only to have them quit. What are you going to do about staff retention? Burnout? Attrition? Internal transfer? I recently heard at a security conference that when people take a SOC job they plan to quit in 18 months.
- How will you know when you have had a success? What does success and failure look like for a SOC? (or a major security purchase?)
- Have you been talking to the auditors again? They said something about this last year. I bought a new firewall.
- Show me a playbook first – can you do that? Come back when that's done.
- IT is outsourced, it is “company X's” responsibility, not ours. We have no liability because that rests with the outsourced vendor and it's in the cloud/vendor contract¹.
- What can you do with a third of that? Because that's all we have.
- We spent \$3.5M on SOX last year. No more!

Identify SOC Services by Development Phase

A Security Operations center can provide numerous services to both the business and to IT. A list of these services is provided in **Table 1-1**. You do not need to build each service “Day One”. Instead, evaluate your current state, staff, maturity, and funding available. Be careful to build out services which will be successful by only taking on a service that you can successfully deliver when your plan and staff are ready.

Determine which service will be built and the order. Understand how the organization can use a given service and how the SOC can acquire and

deliver that service and mature it. It is entirely possible that the SOC will develop a hybrid service inventory with some services in-house, some through a partner, and some fully outsourced.

The core services of a SOC *operations* team are listed below. Your organization will certainly implement these services based on your own capabilities, funding, anticipated service window such as 8AM to 6 PM, 6AM to 12 PM, or full 7/24/365 and the staffing level required for each delivery window.

Table 1-1. Security Operations Center Service List

Reactive Services	Proactive Services	Other Related Services
Monitor Security Posture (Alerts)	Network Security Monitoring	Policy Procedure Support
Initiate & Manage Incident Response	Threat Hunting	Internal Training and Support
Command Function (IR/Analysis)	Platform Health Monitoring & Support	Audit and Assessment
Vulnerability Management	Cyber Threat Intel Generation	Organization facing briefings and updates
Forensics/eDiscovery	Cyber Threat Intel Integration (ISAC)	
Reporting		
Malware Analysis		
Intrusion Detection		
Audit/Assessment		
Notification Refinement		
Log Management		

As you consider each of these services, be sure to incorporate them into your SOC planning process. Here is an outline of the steps involved.

1. Assign them to an implementation phase
2. Ensure the supporting skills required to deliver on each
3. Identify the data sources that enable a service offering are available
4. Plan for policies and procedures to support the service
5. Build out engagement and IR response patterns related to the service
6. Establish staffing to realize that service over the lifetime of the SOC.
7. Build the budget for each service.

The Security Operations SIPOC Diagram as a Service Design Tool

There is a very useful tool that SOC service planning can utilize to diagram out the main elements of a SOC service process: a five-column diagram that lists Suppliers, Inputs, Process, Output, and Customer, or SIPOC diagram. This diagram comes from Six Sigma. If you are interested in using Six Sigma methods, SIPOC's are developed and are foundational tools at the "Define" and "Measure" phase. This diagramming model embodies five elements, with the definition adapted for SOC services and model the processes used to deliver that service:

Suppliers

Anyone who provides the inputs for the process. Can be internal or external.

Input

The resources, materials, or information needed for the process to function; other services may be an input as well. For SOC's, data sources need to be spelled out.

Process

A high-level overview of the major steps in the process, often in four to five steps. Leave the details for the playbook(s). It is likely that processes will include interconnections with outer IT and business teams.

Outputs

The products, services, or information that result from the process.

Customers

The people or departments who receive the outputs, For the SOC application of SIPOC, these are stakeholders, application owners, SLT/ELT, HR, and staff management. An end user may also be a customer, but you will find that end users are often the subject of an investigation.

SIPOC Diagrams are included for these services:

- **Table 1-2** Security Monitoring
- **Table 1-3** Incident Response
- **Table 1-4** SecOps Platform Health Monitoring
- **Table 1-5** Cyber Threat Intelligence

Voice of the Customer

SIPOC diagrams need to include, or make clear, the “Voice of the Customer” (another Sig Sigma term). As these diagrams are developed, ensure that VoC analysis is conducted and included so that outputs are aligned with stakeholder needs.

The “voice of the customer” (VoC) is a business process term. For SecOps, as services are developed, gather and analyze organizational (customer) feedback to understand its needs, expectations, operating environment, regulatory impact, appetite, and preferences for a cyber defense service provided by the SOC. Traditional VoC analysis uses

structured approaches and data from various sources, such as surveys, social media, and customer support interactions. When developing a SecOps function, VoC analysis will most likely be solicited from stakeholders by using well-structured questions and semi formal interviews. Take the time to prepare to collect the VoC.

By acting on this feedback, the SOC should aim to increase organizational satisfaction and loyalty as they execute their mission to defend the enterprise.

Security Monitoring

This is the primary role of the SOC: monitoring the environment for security conditions, alarms, health of the security platform, and responding through the organization's various technical solution(s). Below is a SIPOC diagram for this function.

Table 1-2. Security Monitoring SIPOC Diagram

Suppliers	Inputs	Process Steps	Outputs	Customer
SIEM vendor; EDR vendor; Network monitoring; Proxy/DNS providers; Cloud providers; Threat intel feeds; SOAR/XSOAR; Asset inventory; Identity providers; IT ops; Legal/Privacy	Alerts and events; Telemetry (Sysmon, EDR, NetFlow, DNS, Proxy, Cloud logs); Playbooks; Triage checklist; Asset context and owner info; IOC lists and threat reports; Training materials; Policies and incident criteria	Detect alerts; Triage using playbooks; Enrich alerts with context; Investigate and build timeline; Classify and assign severity; Escalate to IR or remediation; Document findings and update playbooks	Detect alerts; Triage using playbooks; Enrich alerts with context; Investigate and build timeline; Classify and assign severity; Escalate to IR or remediation; Document findings and update playbooks	Security team

When conducting VoC analysis with an analyst, the Playbook rises to the top as a major point of concern. From the analyst point of view, high quality playbooks are necessary so they can manage alerts. Analysts need to have these updated over time with new data sources, searches, and capabilities from the introduction of new systems or updates. Playbooks are one of the main inputs to handling an alert and often have integrations with a SOAR platform. Be sure to differentiate an analyst playbook from a SOAR playbook, which is an automation in a technical platform to enrich data, perform structured messaging, initiate

containment from an EDR, run a script on an endpoint, and many other automation actions.

Initiate & Manage Incident Response

A *significant portion* of the activities and instrumentation of a SOC focuses on finding and validating security incidents based on alarm and NSM work. The SOC may be empowered to initiate specific IR support from vendors, contractors, secondary business units – a wide variety of staff outside of the SOC and IR function. In these cases, an *operational process* needs to be defined with a set of *releasable data* provided to those outside of the SOC/IR team. Don't freelance or make up these points on the fly – plan ahead so that you can show up well. To start planning, review the application inventory and determine if IR support can be handled internally or if a third party needs to be engaged. Once you have planned, exercise your plan at least twice a year using a tabletop exercise format. Once that is stabilized, integrate various real data or activity components into testing the IR plan. Then graduate to engage an external pen test team, outline an engagement structure, and put the blue team to the test.

Manage Incident Response and IR Command

This is usually a recurring activity, as the SOC coordinates alarm response, incident response, and forensic processes. Incident command can be a very intensive process. Incident command means that your SOC will identify incidents, work with handlers, coordinate containment operations, will assist in eradication efforts, take information from the incident and use it to better implement internal systems based on newly found intelligence, and may also support pushing out updates or other fixes.

Here is a macro level SIPOC diagram tailored to the Incident Command Function in a modern Security Operations Center (SOC), using Six Sigma methodology. You can also write out a more targeted SIPOC diagram, to focus on a particular customer if you are an MSSP. The benefit in doing this is that IR commands can target messaging to a particular customer or stakeholder.

Table 1-3. Incident Response SIPOC Diagram

Suppliers	Inputs	Process Steps	Outputs	Count
SIEM/Log Management Systems Intrusion Detection, Prevention Systems Endpoint Detection & Response (EDR) Threat Intelligence Feeds Security Analysts (Tier 1/2) Network Monitoring Tools Vulnerability Scanners User Reports/Help Desk Threat Hunting Teams	Security Alerts & Alarms	1. Identify & Classify	Incident Reports	1
	Log Data & Events	Triage alerts, validate those that are incidents, assign severity	Containment Actions	1
	Threat Intelligence Reports	2. Coordinate Response	Eradication Confirmations	5
	Incident Tickets		Updated Detection Rules	1
	Forensic Evidence		Threat Intelligence	5
	IOCs (Indicators of Compromise)	Assign handlers, establish command structure	IOCs	1
	Vulnerability Reports	3. Contain Threat	Security Patches/Updates	1
	Network Traffic Data		Remediation Plans	1
	System Baselines		Lessons Learned	1
		Isolate systems, block malicious activity	Documentation	5
		4. Eradicate & Recover	Metrics & KPIs	1
		Remove threats, restore operations		0
		5. Intelligence Integration		

Suppliers	Inputs	Integration Process Steps Extract IOCs, update	Outputs	(
		detection systems		
		6. Post- Incident Activities		
		Deploying patches, implement improvements		

Vulnerability Management

The SOC manager may be asked to assist, or even run, a vulnerability management program. The SOC manager should be very cautious not to take on tasking the SOC may not be able to handle : developing and deploying a round trip, full scope VA/VM program. Working through the process of safely finding, notifying, tracking, and attempting to identify the system owner and custodian, and *then gain system custodian and data owner support on remediating vulnerabilities in a timely manner can be a labor-intensive process*. Further, an effective VA/VM program needs to be executed within the business context and concept layer, meaning that the focus of the program should be oriented following a business criticality model. These are all complexities of running a program that can really stretch a SOC.

Forensics/eDiscovery

Depending on the size of the SOC, forensic support may be conducted in-house, or the SOC may coordinate and support forensic examinations with a third party. eDiscovery within an organization often uses the same or similar tools, requires chain of custody during the collection of case specific information, and will also analyze the results of data collection. A key difference is that eDiscovery is focused on collecting search

specific information from live, in use data and information repositories that is generated and used by people. Forensics goes deeper, examining system artifacts from the file system that show intent for users to interact with files and data, malicious software residing in memory, or data deleted from disk.

Reporting

Run reports to support compliance requirements and IT General Controls monitoring. Run reports to support alarms, incidents, and other reporting requirements. Respond to additional data requests.

Compliance, audit, and other regulatory functions often request an array of reporting. It is entirely possible that the SOC may need a half time or full-time analyst to support compliance reporting.

Malware Analysis

If a SOC analyst can safely recover a malware sample, then they may be inclined to perform some lightweight malware analysis using services like Google Threat Intelligence (formerly VirusTotal), Hybrid Analysis, or Any.Run. That advice was useful fifteen years ago and is no longer considered best practice. The better course of action is to run samples through either a closed sandboxing service like JoeSandbox or a sandbox tool integrated in the EDR platform, or a local malware analysis engine built on Cuckoo sandbox. The objective is *to prevent informing the attacker, who is likely monitoring online services, that their malware was found*. Open online tools allow a user to upload a suspect binary and then advise if it is known bad and provide varying levels of activity analysis such as registry changes, new services, file system changes, IP addresses in use, or domain names looked up. If the analysis reveals something suspicious, then the SOC analyst would take that operational intelligence and be able to better search security data. More complex reverse engineering beyond this cursory level is a very specialized skill and requires an environment setup for this purpose.

A malware lab is a commonly provisioned tool. A low-cost system can be built out using virtualization software like ProxMox, scripting to build virtual machines, and isolating the platform from the main network and

providing a stand-alone internet connection fronted by a NGFW in full monitor mode. As an alternative, a CSP could be used to build out a virtual machine but be aware of two issues. First, implementing network security monitoring through packet capture is expensive, and as of 2H25 only Amazon Web Services does this well. The second issue is leaving a malware VM running for an extended time and incurring real costs.

Intrusion Detection

There are several detection systems that can be deployed on the network or on a host. These detection systems (Snort, Suricata, Zeek, PassiveDNS, etc.) all require care and feeding to make sure they are operating properly. Winning the budget to implement a NIDS platform that doesn't maintain the ruleset isn't an optimal solution.

The primary commercial ruleset providers for Snort and Suricata as of 2025 are Cisco Talos (Snort VRT / Subscriber [Rules²](#)) and Proofpoint's Emerging Threats (ET Pro [Rules³](#)). There is also the Snort registered and for a no cost option with a thirty day delay and subscriber Community [Rules⁴](#) (Snort.org).

Alert Notification Refinement and Improvement

For alarm conditions that are deemed valid, create notification with sufficient supporting information for the recipient(s).

This service is often fed by analysts who identify issues with alerts, incident responders who find and correct issues during an incident, a security analytics team, or a CTI function finding new and unique patterns of activity that can be integrated into and improve the SIEM.

Network Security Monitoring

NSM is the collection, detection, analysis, and escalation of indications and warnings based on network level data that indicate an intrusion. One of the best no to low-cost options for NSM is Zeek.

Zeek is a powerful, open-source network security monitoring (NSM) framework. It can be deployed with SPAN/Mirror ports or network taps

to passively monitor and analyze network traffic at the application layer. Zeek produces rich, structured logs and enables custom detection and hunting via a domain-specific scripting language. It's designed for high-performance deployments and deep protocol visibility. Zeek has over 50 application-level analyzers and can also carve files out of network traffic for downstream analysis.

Next Generation Firewalls such as Cisco ASA, Palo Alto Strata, and Fortinet are also capable of analyzing application-level traffic, often analyzing thousands of applications. These systems do need to be implemented as a gateway device to support network packet “break and inspect”. Some platforms also support pushing decrypted traffic out a specific LAN port which can in turn be directed to a NSM platform.

Threat Hunting

Threat hunting is a proactive process that inherently assumes that there is some form of intrusion or breach. Threat Hunting begins with generating a hypothesis of a compromise and then tests that hypothesis. It includes systematic reviews of flows, account activity, and event review both from a longitudinal perspective and in the aggregate. Threat hunting seeks to detect security threats, intrusions, misuse, and breaches by data mining.

Threat hunting has its own chapter in this book.

Platform Health Monitoring

Monitor SIEM dashboards and alert stream, reviewing and acting on alerts following a priority basis. Monitor SIEM platform and other supporting data sources in order to detect issues and work with data custodians to ensure data survivability. Update platform definitions (assets, networks, privileged users, alarms, etc.) as the environment changes. Includes maintaining source data availability and quality by checking to make sure that events are parsed and creating new or refined alarms. Below is a SIPOC diagram for a platform monitoring service.

Table 1-4. SecOps Platform Health Monitoring SIPOC Diagram

Suppliers	Inputs	Process Steps	Outputs
Log Source Systems (Network, Endpoint, Cloud) through a 'platform' Data Custodians/System Owners IT Infrastructure Teams Configuration Management Database (CMDB) and asset management systems Network Operations Center (NOC) Identity & Access Management (IAM) Parsing/Normalization Engines	Raw Event Logs & Data Streams	1. Monitor Dashboards & Streams	Platform Health Reports
	SIEM Platform Metrics (CPU, Memory, Storage)	2. Review SIEM dashboards, alert queues, prioritize actions	Data Quality Metrics Updated Asset Definitions
	Data Source Health Status	3. Platform Health Assessment	Refined Network Boundaries
	Parser Performance Metrics	4. Check system resources, data ingestion rates, storage	Current Privileged User Lists
	Asset, Network Configuration Data	5. Data Quality Validation	Optimized Alarm Rules Custom Dashboard Updates
	User Privilege Definitions	6. Verify event parsing, normalize logs, identify gaps	Parser Configuration Changes
	Alert Queue Status	7. Data Custodian Coordination	Data Source Status Repository
	Data Ingestion Rates	8. Engage data owners for	Event Coverage Gap Analysis
	Event Format Specifications		
	Platform Error Logs		

Suppliers	Inputs	Process Steps	Outputs
		source issues, ensure survivability	
		9. Definition Management	
		10. Update assets, networks, privileged users, alarm rules	
		11. Alarm Refinement	
		12. Create/tune alarms, reduce false positives, optimize detection	

This service offering also delivers different values to different customers, Here are some examples:

SOC Leadership

Platform uptime & reliability metrics, Data quality assurance reports, Resource utilization insights, and Budget planning/forecast support

Platform Technology Owners

Current asset/network definitions, Data source health status, Parsing & integration feedback

Application Owners

Accurate custom dashboard data, Event coverage validation,
Optimized alarm configurations specific to their respective platforms

Cyber Threat Intelligence

This is the analysis of adversaries, their capabilities, motivations, how the adversary uses the cyber domain to accomplish their goals and objectives. There are CTI producers who generate CTI feeds of structured Indicators of Compromise (IoCs) delivered through a variety of means (discussed in the next section). A second example of a producer is reporting and analysis of the cyber domain that your organization can leverage. When considering CTI, you should use multiple sources. Not all CTI sources are the same or offer the same degree of coverage, nor do all processes require the same degree of automation. Lastly, CTI (in my opinion), includes understanding software vulnerabilities and ready-made attacker capabilities. For example, what are the new Metasploit exploits added this week? Metasploit makes the process of exploiting vulnerabilities significantly easier because exploits are encapsulated into reusable code. How quickly does a new exploit appear after a vulnerability is announced in a technology you depend on? By keeping aware of attack tools, vendor announcements, and postings from major vendors from the IR community such as Palo Alto, Sentinel One, ProofPoint, Microsoft, SANS, TrustWave, IANS, major EDR vendors like SentinelOne, Microsoft Defender, Carbon Black, well respected vendors such as TrustedSec, BHIS, and annual reports like the Verizon DBIR. You can build a very low-cost CTI program and then make a purchase decision as you gain an understanding of what CTI is.

A CTI RFI or a Request for Information is a process where a request is made of an intel provider for specific analysis germane to your own organization. RFI's can be very formal or informal, like a request made to a provider. They can also be information, like when a RFI comes from an internal stakeholder. The CTI analyst should take in the request and evaluate the landscape to learn what threats are in play with the specific objective of helping the org to make better cyber focused decisions.

CTI can also be home grown from within. As incidents progress, Indicators of Compromise are generated. These are a piece of trace data observed that is *directly* related to an attack. These IoCs can be used to sweep the network, can be used to retro threat hunt, build a better detection, incorporated into a blocking capability, and shared with the community at large. For a Cyber Threat Intelligence function, here is an example SIPOC in **Table 1-5**.

Table 1-5. Cyber Threat Intelligence SIPOC Diagram.

Suppliers	Inputs	Process Steps	Outputs	Customers
Threat Intel Services ISACs; DomainTools; Infoblox; Recorded Future; Anomali; VirusTotal; MISP; OpenCTI; Vendor CTI (Trustwave, Palo Alto, CrowdStrike); Internal telemetry owners (EDR, SIEM, Network); Legal/Privacy	Reports from CTI providers, EDR vendors. CTI feeds (STIX/TAXII, CSV, JSON); IOC lists; threat reports; raw telemetry; enrichment data (WHOIS, GeoIP, Passive DNS); legal constraints	Ingest and normalize; validate and score IOCs; enrich and correlate with telemetry; triage and analyst investigation; produce intelligence products; operationalize detections and watchlists	Validated IOCs; tactical watchlists; detection rules and signatures; strategic threat reports; alerts and advisories; intelligence packages (STIX)	Security Operations Incident Response Risk Management Detection Engineering Classification IT External Partners IS Management

Threat Intelligence Feed Integration

This is the process of carefully selecting and bringing in threat intelligence feeds from a producer into the system to improve alerting, better identify suspect or malicious sources, destinations, domains, and other patterns. Historically, a feed may be a list of indicators, reporting, or feedback by a security point solution provider that is performing a service for your org.

Today, there are numerous online providers who have API access for very directed questions about a data element because providing that intel through a list distribution mechanism is more difficult. There are a few organizations like Infoblox and DomainTools that have a vast database of domain names and an extensive background in how a given domain name is involved in a cyberattack. In contrast, reporting from a managed service like an email filtering platform can be used by the SOC to keep up to date on adversary messaging tactics. For example, many messaging platform providers can provide a month report out of lures directed against your organization, what else is being seen in your industry, or what the adversary “flavor of the month” for remote access tolling is. There are several ways to measure a given CTI feed. These include accuracy, which is usually measured by a false positive rate, timeliness of their indicators, additional value-add context, and how consumable the feed is.

Threat Intel sources and the information they provide should be on the detection roadmap.

Policy and Procedure Support

Many of the monitoring controls and capabilities should tie directly to established policies and procedures (PnPs). As use cases are implemented, ensure that there is a tie-in to how the SOC will support PnP enforcement. More specifically, as this service area matures, ensure that SoP's are written to define how the SOC will properly engage with the user, supervisor, HR, and Legal in response to violations of PnP's.

Internal Training

Iron must sharpen iron, so the SOC management team must ensure that as the SOC changes the line staff must be trained and kept current. For example, as a new data source is integrated into the SOC, all members need a briefing on the data source and how to use it properly.

SOC Project Planning Outline and Field Notes

Instead of repeating any of that content in BTHB:SOCTH, this section presents a condensed outline for planning a SOC based on the PMI PMBOK⁵. Also, *do not shy away* from using the PMI PMBOK because “project managers are annoying”, “project management is useless”, or “it’s just not that hard”. A solid PM that understands how to drive a project to completion on time, cultivates stakeholder engagement, and within budget is a *tremendous ally for anyone building a SOC or implementing a SIEM*. This section provides a “just the facts” discussion on SOC and SIEM planning. As you read through this section, many of the statements will become elements on a project plan as a “plan the item, conduct the item” line-item entry.

The Business Case for SOC

A SoC can easily be a multimillion-dollar expense for an organization. This section outlines the thought processes, a macro level work breakdown structure, and an outline that you can use.

As you develop the business case, perform research and think through the process and focus on understanding of the organization’s needs and how the SOC can support its goals, objectives, and how the SOC can successfully protect them.

1. Understand the organizational need for a SOC, which means that you need to ***understand your organization’s goals and objectives***. By being able to articulate how the SOC protects what the organization produces, sells, or the services provided to others, the SOC will have more credibility, be relevant to the business, and support your organization’s mission statement.
2. Understand the business problem(s) the SOC needs to address and value chain resources that the SOC needs to monitor. You may need more of a “compliance” focused SOC, a tactical SOC, an Incident focused SOC, or most likely some combination of these. The SOC will monitor several components of the value chain in addition to general IT resources. The SOC that intelligently targets the value chain for monitoring, will be more successful and relevant to the business.

3. Identify the SOC sponsor. The sponsor may have an uphill struggle to initiate, build, and deploy the SOC. The SOC manager must be sure that the sponsorship is well maintained. The “customer” should want SOC services and not have them dumped in their lap. The other operational roles will need to be well staffed. Evaluators and regulators are examples of “external stakeholders”. These roles will be staffed by auditors with varying skill levels who are attempting to measure and report on risk and the degree of compliance within the organization. Understanding the questions stakeholders are likely to ask will inform use cases, reporting, and data sources that should be implemented to report to the SIEM platform.
4. Ensure there is an actual need for a SOC and its supporting logging infrastructure. Be ready to articulate that need and explain how the staff and technical capabilities meet the need. Here, you should develop a formal business case. Be prepared to justify the staff, resources, access, and software needed to build a SOC.
5. Develop a problem statement. In the cyber defense and SOC context, a problem statement is a concise description of a security state, ability to detect and respond to incidents, or capability gap that needs addressing. It identifies the gap between the current security posture and the desired, more resilient state, while clarifying the impact of the problem and setting clear, measurable goals for resolution.
6. Develop key “Security State” understanding (the “as is” versus the “to be” state). This understanding is technical in nature and corresponds to various use cases and monitoring needs from the traditional IT perspective. Wherever possible, connect a security state monitoring capability with a value chain component and the IT General Controls program. Refer to the most applicable standard for your industry, such as the ISO 27002. See page for more information.)

Preparing the Business Case, Charter, and Project Plan

This process will likely be two to eight months' worth of effort. Design the phases, identify the *key inputs and outputs per phase per the PMBOK*, and who will support each project phase.

1. Define the organizational ownership, responsibility, and SOC location. Attempt to locate a physical space that will accommodate twice the head count you will have in year one, so that you don't have to move in year three.
2. Identify the key roles for SOC: "architect", "engineer", "analyst", "manager", "customer⁶", "sponsor⁷", and "stakeholder⁸". Several of these are nearly identical to the roles defined by PMI's PMBOK (definitions in footnotes).
3. Identify the relevant Policy, Procedure, and Governance - in place, or new PnP's that need to be written and adopted. Review existing PPG and determine if they support the SOC. Ensure that the SOC function is integrated into IT processes, particularly new application acquisition, server provisioning, and change management process. Also, the SOC will need to consume the forward schedule of changes, maintenance window updates, and notifications that changes were successful⁹. As a monitoring service, the SOC team needs to know about changes so that they don't over react during change failures or other OS and app changes that may seem suspicious.
4. Document necessary staffing levels, training, and educational process(es). Here, concretely plan for the first year. Once that's done, develop a three-year plan and assume that you will have above average turnover. SOC Analysts are in high demand, and incident responses tend to burn people out. Note that a SOC of one person *isn't a SOC*. It is often a highly motivated person who performs heroic acts and will eventually be burned out, or a single person running a SIEM.

5. For a 9-to-5 model, you may be able to do well with 2 full-time and two part-time people. On the other hand, if you are planning for 7/24/365, you will need a minimum of 12 people, with one manager for the day shift and at least two strong leads for the other shifts for best coverage. 7/24 models also have the complexity of how shift work is designed and staffed. You may also be able to partly or fully “follow the sun”. If you have operations in Europe and North America, you can get significant coverage by starting in Europe at 7 am their time.
6. Conduct a current data source survey. Identify the data sources, their logging configuration, assets, applications, application to server and data store mapping, data or logging suitability for the SOC, and the anticipated volume along with storage requirements. *You should not assume that every candidate data source is well instrumented and has the level of auditing your SOC will need.* As you prepare your data source survey, *preserve vendor and product documentation* that describes how the logs work and what their values mean. You will need this detail later. During this process, you will need to inventory how each data source can provide information to a future SIEM: syslog (UDP or TCP), file write, database table, SNMP traps, etc. Some data sources are very narrow, meaning that the average event is 120 characters. In contrast, NGFW and Cloud IAM logs are very wide because of the sheer number of fields and the physical delivery format when they arrive as JSON or XML.
7. Determine how many endpoints and users there are likely to be in the near term, three year term, and if possible five year horizon. These counts will help you estimate data volumes, event velocity, and estimate storage.

Business Case Outline

If you have never developed a business case, here is an outline of one specific to supporting a security operations center.

1. Executive Summary.

- a. Cover the purpose or why of a SOC. Benefits are such as faster detection, reduced dwell time, regulatory alignment, and improved incident response.
- b. This is a high risk ask, so be as sharp and concise as you can when you discuss budget, timeline, and decision point.
- c. Two key acronyms may be helpful. Bottom Line Up front (BLUF) and Specific, Measurable, Achievable, Relevant, and Time-bound (SMART).

2. Problem Statement and Risk Assessment

- a. Describe the Current state. Include 4-7 measures that are directly tied to the business case such as volume of alerts, mean time to detect (MTTD), mean time to respond (MTTR), and significant coverage gaps.
- b. Discuss business impact factors. Examples include potential revenue loss, compliance fines (and be specific here, like tie them to a contract, market, or division), brand damage, and operational disruption.

3. Objectives and Scope

- a. Primary objectives: Define the monitoring schedule. Consider a 6d/12h model and then define 24/7d/24h. You may get funding for 6/12 easier than 7/24, and it takes quite a bit of work to get to a functional 24/7 model.
- b. Scope options: In-house SOC, co-managed, MSSP, or hybrid. If you are using a third party you may get questions on who does what.
- c. Services included: SIEM, SOAR, EDR, threat intelligence, forensics, and more.

4. Benefits and Value Proposition

- a. Quantifiable benefits: Examples include reduced MTTD/MTTR, fewer successful breaches, reducing dwell time, lower incident costs, insurance premium reductions.
- b. Operational benefits: Centralized visibility, automated playbooks, and consistent incident handling.
- c. Strategic benefits: Faster recovery, improved customer trust, and regulatory readiness.

5. Cost Estimate and ROI

- a. Cost categories: People (analysts, managers), technology (SIEM, SOAR, EDR), facilities, training, and ongoing threat intel.
- b. Business cases include a ROI and Break Event analysis. Most security projects take a cost avoidance approach, however, as they are not profit centers, so this may prove to be more speculative or difficult to develop.

6. Implementation Roadmap

- a. Business cases usually outline a roadmap, often in table or bulleted form. The degree of roadmap planning is highly dependent on the formal nature of your organization. Time invested in a roadmap will go a long way to develop the work breakdown structure (WBS) of an actual project plan, if your business case is approved.
- b. Phase 1: Design services, perform tool selection, and conduct a pilot.
- c. Phase 2: Include an outline of data source onboarding (described in the next section).
- d. Phase 3: Build, integrate, hire/train.
- e. Phase 4: Operate, tune, measure.

- f. Milestones: SIEM ingest, playbook library, 24/7 coverage.

7. SOC Governance and KPIs

- a. Governance: Roles, escalation paths, SLAs, and other factors that define how the SOC will operate.
- b. KPIs: Each defined service should include specific measurements. Examples include alerts triaged per day, MTTD, MTTR, false positive rate, incidents contained, time to containment.
- c. Reporting cadence: Weekly operational and a monthly or quarterly executive report may be necessary. If the SOC is using a third party, make sure to cover how the organization is managing that contract.

8. Risk and Mitigation

- a. A solid business case *will discuss risks* and how to counter them. One piece of advice: do not use this section to express Fear, Uncertainty, and Doubt (FUD), which is a disinformation tactic. Be sure to avoid this at all costs. Make a point to clearly state assumptions in your analysis.
- b. Risks: Talent shortage, tool sprawl, complexity integration, staff turnover, the tempo of adversary operations *specific to your industry*.
- c. Mitigations: Co-managed model, phased rollouts, automation to reduce manual triage.

Environmental Data Inventory Survey and Planning

Not only do you need source operating system data, but you also need metadata about the network, organization, users, applications, and a mapping of the business processes that depend on the organization's applications, known as an environmental data and inventory survey

(EDIS). EDIS¹⁰ begins with developing an inventory of major business processes along with the business process owner. From there, define the applications that enable said processes, and then the servers that support the applications, which is like BIA, BCP, and DRP planning. The difference between SOC/SIEM focused EDIS is the depth of information. BIA, BCP, and DRP are focused on bringing an application, data, and servers back into service, whereas SOC/SIEM is focused on enabling monitoring, understanding who to contact for an incident, establishing baselines, and being able rapidly investigate an incident. Both processes collect similar data sets, and can complement one another. Data includes users and their demographics, network maps, address ranges, applications in use, app to server mappings, app to RDBMS (or other data storage), input/output streams, web services that the application uses, and the overall organization chart. Many of these data sources will provide information to the SOC and the SIEM through automation, so ensure to get at least “read only” credentials for the systems that house this information such as a Configuration Management Data Base (CMDB).

Data onboarding is a multi-step process and is critical to detection engineering. The steps below assume that the data owner has agreed to provide data into the SIEM.

1. Determine the most reliable and practical log transport method for data to be delivered to the SIEM.
2. Confirm the date/time format from the source, if it can be delivered in UTC, and the actual date format (YY/M/D, M/D/YY, etc).
3. Match the data to a parser or extractor.
4. Review field based inbound data to ensure it will be viable and usable.
5. Determine useful field enrichment(s).
6. Build out use cases. At the project plan level, you just need a list of use cases or an estimate of the count. If onboarding checks

out, then proceed for full use case development and SecOps response patterns.

7. Acquire a representative sample, assess it for fit, check the different event types to ensure use cases can be satisfied.
8. Establish retention parameters. Estimate volumes, storage requirements, retention requirements, and assess the sensitivity of the data to determine access control requirements.
9. Validate data sensitivity. It is vital to determine if regulated fields such as the ePHI designated record set or sensitive data are present.
10. Onboard the given data source, monitor volume, and develop data survivability monitoring. The objective is to detect, as rapidly as possible, if the data source has stopped reporting within an acceptable period. For a firewall, that may be 5 seconds. For a back office application, it may be 60 minutes from 7 AM to 10 PM Monday through Friday. A frequently used SaaS application may be 15 minutes.
11. Assess for refinement and filter out conditions that have no security value.
12. Begin use case development. In parallel, initiate updates to SOC playbooks to support new use cases.
13. Develop a data field dictionary, and design and deliver SOC training so staff understand how to use data on a day by day basis.
14. Lastly, ensure that your data provider understands that if there will be a system change for the source system, the SecOps team needs to quickly detect a problem with data delivery and field format so the SOC can be ready to respond to the change.

Project Management and EDIS Steps

From a Project Management perspective, the major steps for the EDIS process are outlined below.

1. Identify and develop an inventory of major business processes and departments. The objective is to understand what data sources and use cases need to be created to monitor and defend these processes. Note that this information may be readily available from a BCP and DRP plan.
2. Review the asset and network attributes necessary to best populate the target SIEM in order to maximize the data collection process.
3. Identify the applications which support business process, along with the data owner and system custodians, and from there document an application to server model, and thus the inventory of technologies in use. In many SIEM platforms this relationship will be implemented in an asset model, which supports more accurate alarm rule development.
4. Develop an inventory of every security focused or IT support technology. A sample list is shown below
 - a. Network devices: Firewalls, IDS, VPN, DNS, DHCP, NAC, WiFi, WIDS, switch logs
 - b. Technology Support systems: Mobile device tracking, Anti-Virus, Enterprise Detection and Response (alerts), Vulnerability Scanner, Password management system, web proxy, Email, virtualization platform, database systems
 - c. Windows focused event logs: Application, Security, System, Sysmon Operational log. Note that as a subproject, the SOC implementation may need to spin up a separate project to implement WEC/WEF.
 - d. Application logs: these usually require a database query or some other method of data collection
 - e. Other relevant tools: Email security tool, Insider threat tool, System Backup logs

5. With the list of applications and security technologies, a line item for each item can be created in the project plan.
6. Estimate the number of hours to incorporate the data source for the use cases - these items will expand in a subsequent phase, following the “progressive elaboration” model.
7. *Include a project specific line item* to develop a briefing for the SOC team that explains each data source’s field set and field values.
8. Build your SOC Metrics, as defined in Chapter Three, SOC Metrics.

For each of the identified data sources, you will need these planning and implementation elements:

1. Determine how the data source will be collected. Consult SIEM Data Collection Methods and Considerations for more information on SIEM data collection methods.
2. Review the current auditing and logging configuration for fit.
3. Estimate to the extent possible the volume of data. For this point, try to get an average daily volume over at least a five-week period, which should catch any surges that naturally occur across a month’s boundary.
4. Determine if data can be trimmed, meaning review the data to find out if there are low to no value records provided by the data source that can be pruned or dropped either at the collection point or the arrival point.
5. Inventory the data fields from the data source and develop an internal SOC training program so that all SOC staff understand the data source.
6. As needed, implement the necessary change control to configure the data source to report to the SIEM.

SIEM Technology Provisioning

Plan the Technology provisioning process to support the SIEM, and another identified SOC services. Plan for twice the data you think you will need in year one.

1. Hardware: Including disk and disk controller architecture, as influenced by logging requirements and SIEM platform.
2. Virtualization Layer: Modern virtualization technology makes virtualizing your SIEM a very attractive option. When considering this option, it is critical to articulate the data speeds in terms of IOPS necessary for databases and/or data storage – don't assume that this will be handled by your infrastructure team.
3. Log storage architecture, scripting, and long-term storage requirements. For long term storage, you really need space over speed, because you rarely go back to data past a 90-day threshold. Reliable, safe, and large long-term storage is more important than blazing speeds. Blazing speed is needed for the past three days' worth of logs. For Cloud supported log storage, determine the "hot, warm, cold" model specific to the platform so that you can budget this recurring expense.
4. SIEM and supporting software. Note that most major vendors have their own predefined project plans for implementing their software, which you should leverage to the fullest.
5. Spend time on the Budget Process. A SIEM is a major enterprise-wide application, and it deserves the same budgetary rigor as with any enterprise project. This means building a first-year model to get started, 3-year projection, and then a 5-year projection model. A significant component of the budget development process is developing the Total Cost of Ownership model. You will need to know your organization's technology refresh mode to plan for system replacement. You should assume 50% log storage growth year after year.
6. Application and IT resource data provisioning and possible development. This phase is where you will design how each application and data source will be integrated into the SOC and

SIEM. It usually involves some significant custom development efforts. Each data source brings its own capabilities and will need some form of alert support.

7. To make this process work well, *find the gaps* in the security posture of your organization and work to *quantify* risks. To get this done, find your risk management subject matter expert (SME) or Point of Contact (POC) and partner up with them.

Build your hybrid log architecture, source data collection delivery, and SIEM and logging deployment plan. There is more information in the SIEM Deployment Checklist in Chapter XX. Briefly:

1. Perform software and vendor selection based on a scoring model built from use cases that correlate to your business model, unique data sources, ability to integrate with cloud and SaaS solutions, understanding your compliance requirements, and the overall Cyber Security program.
2. Review the auditing stance and build out the Events Per Second (EPS) rating for each of the systems in the environment that will provide data. Then plan for a 50% increase so that your solution can weather an “event storm”. It’s critical to determine the EPS *after* the source system has had its auditing level configured!
3. Provision the hardware and storage platform and implement.
4. Monitor your data feeds, reporting, and system response time.
5. Build your data integration plan for commodity sources, and carefully select customized sources. For example, an ERP application is not likely to be supported, so you will likely need to develop a database query to pull data from the audit table, implement auditing, test, develop a method to archive current data to a historical table, and monitor to ensure that the query process has minimal system impact.

Build out use cases

1. There are chapters in this book on building out use cases. Review all of that material and compare it against the use cases

in your chosen platform.

2. Plan how to implement the vendor-defined use cases as these should provide baseline coverage.
3. Forecast the effort required and data sources to implement your own custom use case.
4. From there, prioritize the implementation so that you will have project measurement that supports defining earned value.

Build your response processes.

Response processes are enabled by the variety of data arriving, applications, business processes, and your requirements.

1. Response processes will be driven by your security program and the applicable standard you are following.
2. This part of the planning process should answer incident resolution questions like this: “When we get condition A from system B, what does the analyst do and what data is necessary for the system custodian to resolve the incident?”
3. In effect, the process of pulling data into a SIEM will provide the SOC function with dozens of scenarios that need to be worked through. As you build these processes, ensure that you are *outcome focused* – what objective needs to be achieved based on security condition X, Y, or Z presenting itself?

Build and implement your continuous training program.

Training is constant. SOC skills need to advance as the attacker’s skill and determination advance. Ensure that there is budget for at least two tiers of education. Provide premium education for the more senior tier and then develop OTJ training for the junior tier. OTJ should consist of knowledge transfer, short courses, and job skills focused education. Investigate your local community college workforce education program and capabilities in the area.

There are several open-source or very low-cost options. Consider ENISA, SecurityTube, SANS Cyber Aces, local BSides conferences, and

the annual Security Onion conference as more inexpensive education options.

Collect the Bread and Butter Data Sources Using Your Data Onboarding Plan

There are many baseline systems that need to be monitored because they represent key data sources that you need in an incident and support compliance. This is part of the EDIS process. Each data source is likely to need its own onboarding plan, and you may well have the same data delivered in two different ways. At an absolute minimum, these information systems and data sources to collect are:

1. DNS activity, with a focus on internal to external activity first and foremost.
2. Windows Domain Controller core logs – Application, Security, System, PowerShell, and Sysmon Operational event logs.
3. Most, if not all, Windows member servers with at least the Security and Sysmon log.
4. Cloud Identify and Access Management platform (Okta, PingID, Entra ID, etc.).
5. *Account life cycle, process execution, and presence* indicators from workstations. This item is best accomplished using Windows Event Forwarding and event subscriptions *because this is a native* built-in capability in Windows and prevents the need to deploy yet another agent.
6. Email filtering platform.
7. Perimeter firewall. At a minimum, any outbound ‘denies’, accept and deny traffic to the DMZ, and platform changes. If you have capacity, collect outbound accept events as well, provided you cannot get a better data source for the communication flow. For example, if you have a proxy, you can consider not recording firewall data to/from the proxy if you can

get the proxy logs. Proxy logs are superior to firewall logs as they are application aware and are user attributable whereas firewall data is not usually user attributable.

8. Database Account activity and account management.
9. For Linux, the minimum to collect are the sudo, auth, and authpriv logs. For all systems. Don't take "No" for an answer.
10. Antivirus centralized console data.
11. EDR Alert events.
12. Forward (outbound) proxy data. For the proxy, validate that the system records the user agent, referrer, the URI query string, and the allow/deny decision. If the proxy understands the site type, that is also useful.
13. Document editing "in the cloud", such as Google's GSuite or Office 365. This means who touched which file and how.
14. Shared Storage file system activity, as in who touched which file and how for the user and process exposed shares.
15. VPN activity.
16. DHCP transactions.
17. Network device authentication which usually arrives through RADIUS or TACACS+. Further, network change detection, which usually comes from Syslog events.

Once you add your own "must have's" to this list, your next task is to get the daily data volume for each source. Volume has three factors: events per day, average event width, and the typical peak or spike times. From there, you can estimate the capacity you will need for your platform.

Some Useful MBA Concepts: Value Chain, SWOT, and PESTL

There are several business management concepts that help when designing, planning, and building a SOC: the Value Chain, SWOT, and PESTL.

The Value Chain Tie In

One concept that IT people don't often understand or embrace is the business "value chain". The value chain is the set of activities that take inputs and convert them into an outputs which brings a valuable service or product to their specific market. Value chains consist of: resource generators, inbound logistics, manufacturing or service operations, marketing, outbound logistics or service delivery, and after "sale" service and support operations. Today, there are very few aspects of the value chain that aren't dependent on some form of information technology, both of which can be on-prem or delivered as a SaaS solution, all of which must be monitored and fully secured following an IT General Controls Program.

For the SOC, and IT in general, to be relevant to and communicate with the business, they must understand how the business speaks, and the business' context and concept of operations. Formally, a value chain should create some form of competitive advantage in the market.

The DR/BCP team can be very useful in identifying critical services.

SWOT Analysis

SWOT is a strategic planning technique used to help an organization identify the Strengths, Weaknesses, Opportunities, Threats that every manager should understand, and be prepared to use in strategic planning exercises. Building a SOC is an *internal business venture*, which is affected by both internal and external pressures. SWOT analysis will improve your business case for your SOC, will also help you plan, *and if done well can help identify adversaries that will launch attacks against the organization*. Below is a very brief example to give you an idea what a SWOT analysis for a SOC project could look like.

Table 1-6. An Example SWOT Analysis

	Traditional Business Mgmt.	Security Operations Example
S	Characteristics of the organization that provides advantage over others	Technical controls and monitoring capabilities; strong perimeter controls; Policy/Procedure in place and followed; valuable IP in place is protected (and targeted).
W	Characteristics at a disadvantage to others (competing projects)	Moderate Funding; staff and skills; volume and quality of log data; some log sources or logging capability missing from critical applications.
O	Items in the business environment that can be exploited (does not mean technical exploit!)	Improving security software; Implement awareness training; local University has Cyber program; Current VA program is semi structured.

	Traditional Business Mgmt.	Security Operations Example
T	Items that can cause trouble or thwart the project	Increasing stealthiness of malware; trusted insider can defeat controls (accidental or can be disgruntled); ownership; resistance to response from alerts; management expectation to “find the bad guy” is high.

PESTL Analysis

PESTL (**P**olitical, **E**conomic, **S**ocio-cultural, **T**echnological, and **L**egal) analysis is a framework of the macroeconomic and macro environmental factors pushing against the organization. It is used by strategic management, marketing, and business development teams who need a solid understanding of how the organization will perform given a particular business venture. PESTL analysis will help SOC planning along two dimensions: the change and pace of technology that the organization consumes or produces, and the legislative or regulatory environment where the organization operates *and has a presence* that requires monitoring.

Funding the SOC

Always remember that an organization has a specific mission or goal, and it articulates a set of objectives to achieve its goal in a mission statement. Since the SOC team is rarely a profit center, it should ensure that funding requests are aligned to the organization and the applications that enable the business.

Understand the App Stack. The SOC leadership team needs to understand how the organization is funded by its value chain, and in turn how much of the IT spend that SOC may receive in both Capital Expense (CapEx) and Operational Expense (OpEx). Practically, this

means that your team needs an inventory of the business applications by their criticality, and then a map of the servers, database(s), storage, and network connections that enable and support these applications. With this model in mind, you can then work to align your monitoring controls, capabilities, and instrumentation to support the availability, integrity, and security of those applications. Your Disaster Recovery Planning / Business Continuity Planning (DRP/BCP) team can be highly valuable as they have a criticality-based view of the application stack. If you don't have a DRP/BCP team, then build the app inventory yourself with the intention that the work can be used for SecOps, as it will assist IT when there is a need for a recovery event.

For example, your organization is likely to have an eCommerce presence. There are several components on the eCommerce chain: digital storefront, order processing, messaging to the customer and supplier, the WAN link(s), back-end data storage, staff that manage all of these IT components, and protecting credit card transactions. In that list alone, there are dozens of servers, technologies, people, and processes. Therefore, if the security team can put monitoring and incident response in place so it can detect violations in baselines and provide assurance that the components are working, it is supporting the company mission and the ability of the business to sell goods and services.

Finalize the Reasons to Fund SecOps: There are many, many reasons for funding security operations and the logging infrastructure that SOC's and SIEM platforms require.

1. Regulatory compliance (HIPAA/HITECH, Sarbanes Oxley, and others).
2. A prior incident may initiate a funding event.
3. Management Directive out of a genuine desire or a fear response.
4. Your chosen standard that defines how IT is structured, and are therefore audited against, may require SOC and a logging platform.

5. Logs within a given system are volatile. Some systems, like a Windows domain controller, only hold log data for a few hours and then the data rolls and is lost forever. Some systems hold data in memory, in a buffer, and when power is lost or the power is lost, so is the data.
6. Without Logs, you have no ability to go back in history and find issues – security, operational, or change related.
7. It is, in fact, “the right thing to do”.

Security Operations Centers Cost Components

There are numerous cost components to consider when building a Security Operations Center. Below are many of the common cost components. For each of these costs, carefully analyze your current environment as you develop a “build vs. buy” analysis.

Direct Costs

There is more information on this below this list.

Internal Staffing Level

A 24/7/365 requires at least 11 whole people, using the barest bones staffing model. Target 12-14 staff people and one SOC manager, with a lead analyst for overnight work.

Vendor neutral Training

Some examples are SANS, Security Blue Team, Security University, CompTiA CASP, and ISC2 SSCP.

Product Training

Siem solutions have training provided by the vendor.

Tools

Desktop Infrastructure, OS, Office, SIEM license, and investigative tools.

Subscriptions

Soc's will have several subscription services, and in particular, threat intelligence services.

Hardware

Server, storage, and network Infrastructure. Be aware of the typical hardware refresh cycles – usually 4 years.

Forensic Hardware

Forensic hardware has unique requirements because these systems are usually isolated onto a small LAN in a locked room. For example, a customized forensic workstation known as FRED can cost \$5K and up, storing images on central storage can take many terabytes, and write blocker kits can easily cost \$1K and up.

Software licensing costs which include annual maintenance

Software includes SOC support, additional licenses for various management consoles, SIEM platform, ingest costs, forensic packages, PDF generation applications, BI¹¹ tools, and eDiscovery capabilities.

Facilities

Soc Room, furniture, shared large format monitors or projectors, and proximity card or possibly biometric door control. Also, the forensic analysis space should have its own separate locks and proximity card control.

Upgrades

Annual upgrades – often handled on a SoW basis with the vendor.

Vendor assistance

Over time, you will need vendor assistance for new content, improved reporting, more training, and possibly upgrades.

Indirect Costs

1. Recruiting costs such as a portion of building, recruiting, and staff pay increases.
2. SIEM Selection costs for the initial project, which includes labor expended to specific, review, and select the primary SOC toolset.
3. Developing on-the-job (OTJ) training for your SOC staff. Note, this will tie up key SME's and the time commitment cannot be underestimated, so there is an opportunity cost.
4. Integrating new data sources, which may require customized data parsers, alerts, and reports to be created within your platform.
5. Periodic internal or external audit support.

Staff Cost Considerations:

A Security Operations Center needs to be staffed by skilled Information Security Analysts. Period. Shiny SIEM solutions don't solve cases, educated and seasoned people do.

After working in InfoSec since 2001, I can confirm it's just that simple. Highly skilled people can produce more accurate and timely results with a moderate product set than novices with a super expensive shiny toolset.

Base pay, benefits, and the inevitable staff turnover disrupts the cost model. The US Bureau of Labor Statistics lists Information Security Analyst median pay at \$98,350 in **2023**. If your internal overhead load is 30% for administrative costs (SGNA), a loaded position costs \$127,855/year. At this rate, that is \$639,275 for five people per year in 2023 dollars.

The staffing cost is further influenced by the *coverage model*. If the team operates 24/7/365, that requires 4.52 people, or 5 FTE's *at a bare minimum to staff the SOC with a single person staffing the facility. A lonely job indeed.* This value is based on 8,760 hours per year, two weeks paid time off and 8 holidays which yields 48.4 work weeks, or 1936 hours of coverage per person. Any 24-hour

operations team should plan on at least nine people to accommodate vacations, sick time, and staff turnover. Five people will cover the shifts, and the remaining three will provide additional coverage during high activity hours, such as 7AM to 7PM and some Saturdays. Missing from this estimate is the percentage of “admin” time. Admin time consists of all other company required tasking that detracts from conducting actual heads down job duties.

Incident response has a very *high burn out rate* compared to other technical professions. Therefore, to compensate rotate your SOC front line through different SOC services so that they have variance in job duties. Also, look for analysts that aspire to move up and not stay doing the same thing every day. SOC managers should always evaluate opportunities to vary the job duties in order to retain people.

Facility/Space

Most organizations have a per square foot rate for office space that should be in the cost structure. As an example, the average 2016 cost per square foot in Atlanta, Georgia was \$20.01 for Class A space and \$16.36 for Class B space¹². In 2025, that cost rose to \$31.70 /sq ft. for Class A space. There are other single purchase costs, however. For example, you may want two large format monitors and PC's to run them with everything mounted on the wall. That could easily be a \$4,000 single event cost item.

Vendor Neutral Formal Education

Assuming you can find security people, you will still likely need to train them in SOC operations. Courses to consider are “SEC450: SOC Analyst Training – Applied Skills for Cyber Defense Operations”, “SEC504: Hacker Tools, Techniques, and Incident Handling”, “SEC511: Continuous Monitoring and Security Operations”, and “SEC599: Defeating Advanced Adversaries - Purple Team Tactics & Kill Chain Defenses”. Then there is a wide selection of cloud-focused security courses.

Product Training

Every major SIEM vendor has a series of product training courses. These are usually included in the initial proposal and implementation. There will be a cost for new staff as they come onboard. To defray the cost, I've had success by asking for a training credit with an upgrade, system enhancement activity, or adding in a new product component.

Organizational specific training

On the job training will be a continual process. There are numerous studies that quantify the cost to develop robust and reusable training. Data from The Association for Talent Development¹³ listed the time to develop an hour of instructional delivery (a formal class) between 43 to 185 hours for stand-up professional instruction, with numerous factors affecting the time. Don't count this lightly, and don't ignore it. For concise insight into the learning organization and how valuable it is to the company, review Chapter Seven in Paid to Think by David Goldsmith.

Desktops

Analyst hardware, monitors (the more, the merrier!), monitor arms, client-side software, analyst licenses for dozens of applications, furniture, and lighting. Think Quad 24" or 27" displays, and an Ergotron type quad arm. Nice!

Vendor Support

Dedicated vendor support for the security product suite, use case implementation, and continual upgrade processes. These support relationships are usually priced on a per hour basis with a minimum number of hours per week. If your SIEM vendor charges \$225/hour and sells this support arrangement with a minimum of 4 hours, the annual support cost is \$46,800.

Infrastructure

Back end servers, sensor platforms, network instrumentation such as a TAP, and multi-tiered storage. Plan for a per server hardware refresh at 3-4 months before your server maintenance period to

ensure you are not paying a premium for keeping a server online outside of its maintenance window. If you need six servers at \$8,000 each, that's an initial capital outlay of \$48,000 just for the hardware. Plan for 20% annual maintenance, and technology refresh at the four-year mark. Most of the SIEM implementations I've done were virtualized using VMware 5 and 6. This model can be quite successful – but you will need to add in the cost for the Hypervisor. When it comes to actual capacity, spec 2 more CPU's and 4 more GB of memory that you think you need and virtualize your platform on just that server. The long-run benefits you will gain are tremendous. These include volume snapshots, copy over to the new platform during tech refresh, and the ability to more easily mix and match drive configuration.

Integrating new data sources

To minimize impact as new systems are brought online, incorporate the SOC engineering staff in the IT provisioning process. The objective is to ensure that new systems or major system updates can provide relevant log data to the SIEM/SOC team. *This labor charge should be assigned to the application or system, not SecOps, and is a recurring cost item for the life of the SIEM.*

Content Development

Developing new and refining current *use cases* within the SIEM solution. Current use cases will also be updated based on improvements from the threat hunting team. The better you define the input data, content needed, analysis, rules, notification, SOC actions, and outcomes desired, the more accurate a cost you will have and the higher the opportunity for success.

SIEM Software

Siem platform licenses are most often driven by a sizing factor. Typical factors are the “ingest” rate in events per second (EPS), GB per day, or monitored device counts. You will find there is a class of non-security relevant events that arrive at the SIEM along with the data that's really needed. Depending on numerous factors (event cost,

processing horsepower, log storage, event width) you may want to develop a tiered logging method. Costs can vary widely here, from \$20,000 per year and on up. The better you define your environment, the better an estimate you will get from a vendor.

SIEM Software Upgrade

Some upgrades for enterprise systems can be performed through an update process, and some cannot. Experience with five different platforms leads me to advise that a complex upgrade, such as a major upgrade, may be better off outsourced to the SIEM vendor. A typical SoW will be 40 to 80 hours at the vendor's rate plus travel and expense. Ensure that you investigate this fully with your vendors and integrate at least one annual upgrade event to your platform.

Audit Evidence Support

The SOC is often asked to support reporting on security event data and incidents in direct support of an internal or external audit. Staffing this specific role is closely related to the regulatory environment and how often auditors make requests. To estimate this, determine how many audits your organization responds to per year and the reporting needed to support those audits. The SOC team should always record their time to support audits, as this is a service to the business. If you have recurring audits tied to a particular unit, then ask for accounting charge codes to document costs for the SOC to support operating units.

In House vs. Outsourced vs. Hybrid SOC

Now that you have a structured outline of the costs and most of the long-term factors involved in building a Security Operations Center, you are in a better position to consider the pros and cons of outsourcing part or all of the SOC function. Some empirically based observations on engaging outsourced Managed Security Service Provider (MSSP's) are listed here:

1. Startup time will have an impact. MSSPs in effect deploy a partial to full SIEM solution on your network. Each data source

needs to be integrated into the platform, hardware will need to be deployed, and your organization will still need to define your own incident response process.

2. An MSSP will only be able to go just so far when investigating alerts. If you are fortunate, the MSSP can cover 50% to 70% of the alarm conditions well and will engage your organization on 15% of the observed alerts.
3. MSSPs will *never know your network like you do, and you cannot easily quantify this impact to their quality of service delivery*. MSSPs also are unlikely to know what changed on the network, as they rarely participate in change control.
4. MSSPs work with you through a defined SLA and reporting relationship. They cannot replace your own staff who can reach out directly to a system custodian – this is an invaluable benefit to having in-house staff functioning in a security operations role.
5. Their opinion on alarm sensitivity and configuration *is not your opinion* because they tend to look at “genuine threat” conditions, and will ignore or tune out many other conditions. Your use of SOC should include policy issues, threat hunting, audit reporting, and gleaning operational value from the mountain of data the SIEM will consume.
6. There are some tasks that should be outsourced *if they are infrequent*, like system forensic analysis. However, the battlespace of today tells us that we need a memory image more than a disk image. This is nigh impossible for a third party outsource MSSP to collect but may within their ability to analyze.
7. You cannot delegate responsibility to a third party for the security of the assets under your organization’s care, no matter how much someone tries to convince you that you can. You may be able to delegate authority to operate, but not the responsibility of system security.

8. 7/24/365 monitoring by a third party will cost you less for the labor component than building your own 6-8-person team. There is no getting around that fact. If you are being pressured to outsource, realize this argument and devise ways to respond to the argument.
9. MSSP's may also be able to perform system upgrades and very likely have done more upgrades than you. Factor in the cost of your deployment a week or two to perform an annual upgrade.
10. Lastly, you get out of a MSSP relationship what you put into an MSSP relationship. If you do not invest time, then don't assume that they will give you stellar results.

Getting into the Hunt

Historically, SOC would monitor a variety of prevention-oriented systems and respond if one, or many, of these platforms alerted the team. Then they would spend time validating the alert, communicate with the system custodian, owner, or the end user, and if the situation were an incident, they would respond.

The “reactive or detective only model or posture” from the 2000's is no longer effective today. Today's SOC teams need to change their focus, assume that there is a likely compromise, become detection oriented, and *proactively mine* the vast amounts of data coming into their systems and actively look for patterns of intrusion and misbehavior. Proactive threat hunting is an ideal career and skill development path for SOC analysts. Once they understand all of the organization's data sources, know how to handle alerts, and demonstrate that they have established research skills, capitalize on that and get them involved in threat hunting. Depending on how the SOC team operates, you could have a SOC analyst who can perform hunting one day a week, one week per month, or take a particular hunt pathway.

The SOC Directly Supports the CSIRT Function

Today, the need to develop some form of Computer Security Incident Response Team (CSIRT) function can't be ignored. In many organizations or industries, a CSIRT is mandated by specific regulation. The need for a CSIRT is especially true with modern malicious software running rampant, automated ransomware, industrial espionage, criminal elements, nation state grade hacking teams, and host of other aspects of digitally based asymmetric warfare. Sounds sensational, doesn't it? Today's cybercriminal will exploit any weakness they find to extract untraceable digital crypto currency from any potential victim. Regardless of the degree of sensationalism, there are several reasons to advocate for and build a CSIRT function in your organization, which is in turn supported by the SOC function.

1. The SOC provides an active detection capability that should enable early response and limit the long-term impact from an incident. The CSIRT can then coordinate responding to an incident with the goal of identifying, containing, and reducing incident impact. Further, the CSIRT function can return Indicators of Compromise or IoC's back to the SOC so that the SOC can perform historical data analysis, such as searching for internal systems that communicated with a found IP or domain name. Thus, a more mature CSIRT and SOC team can capitalize on a Threat Hunting capability in order to seek out and find a malicious agent that was recently on the network.
2. The CSIRT influences, supports, and fully leverages the security spend. It helps to ensure that the SOC tooling is in place and will support incident response and Security Operations. Or put a different way, having a single CSIRT should ensure that the best tool for the environment is in place, can be leveraged, and others are decommissioned in order to maximize the dollar investment.
3. Maintain objectivity when interacting with internal staff, classifying incidents, and prioritizing the response process. One of the challenges that a CSIRT will need to deal with is staff relationships and maintaining objectivity. Like the HR function, which is charged with enforcing company policy and procedure

in a uniform and consistent manner, the CSIRT needs to be objective, perform its work to protect the business, and avoid playing favorites.

4. Lastly, regulation. There are numerous aspects of the business environment that mandate an incident response capability. These include, but are not limited to: HIPAA/HITECH, PCI DSS 3.2, and Sarbanes Oxley compliance.

IT General Controls Policy and Procedures that Support The SOC

In a very formal sense, Security Operations must be supported by formal IT General Control focused Policy and Procedure (PnP). These documents define how the business and IT operate and, quite literally, define rules for how staff should conduct themselves when using assets that support the business or organization.

Security Policies that Support the SoC

Acceptable Use Policy

Defines acceptable use of organizational assets, IT systems, applications, and systems. Some permit “occasional and infrequent personal use”, some do not. Pay attention to how “enforcement” is defined.

Data Management Policy

Outlines data classification, storage, and protection procedures. This PnP helps to define conditions where data storage rules are violated and put the organization at risk.

Software Asset Management Policy

Governs software installation, updates, and removal.

Secure Configuration Management Policy

Ensures secure configuration of systems and devices.

Account and Credential Management Policy

Manages user accounts and access credentials, and can drive the development and maintenance of many use cases.

Vulnerability Management Policy

Identifies and remediates vulnerabilities in systems and applications.

Audit Log Management Policy

Collects, stores, and analyzes log data for security incidents, telemetry, and visibility of IT systems.

Incident Response Policy

Outlines procedures for responding to security incidents. The Policy itself should define the ownership, need, and life cycle for a Computer Security and Incident Response plan (CSIRP), but *not* define one. This PnP should also make it abundantly clear that all staff must respond in a timely manner to requests from the SOC in support of an incident.

Service Provider Management Policy

Governs relationships with third-party service providers, and in particular, log delivery and incident response ownership.

Security and IT Procedures that Support the SOC:

Incident Response Planning

Develops plans and procedures for responding to security incidents, may further define the CSIRT, and must include how any new system supports the IR process.

Threat Intelligence

Collects and analyzes threat intelligence to inform security decisions and access to CTI data.

Vulnerability Management

Identifies and remediates vulnerabilities in systems and applications, along with a severity rating and response time, and requirements to support a “break the glass” response process when the vulnerability is severe enough to mandate patching in the presence of an eminent threat. This procedure should also clarify how patching intersects with formal Change Management processes to empower system custodians to patch in the presence of an eminent threat.

Penetration Testing

Defines how the organization authorizes and conducts regular penetration tests to identify vulnerabilities. The reporting cycle and criteria for developing a “CAP”, or Corrective Action Plan should be covered.

Security Awareness and Training

Provides security awareness and training for employees.

Continuous Monitoring

Continuously monitors systems and devices for security incidents.

Examples of Security Incidents due to Lack of Policies or Procedures

MOVEit Transfer Supply-Chain Breach (2023)

Mass data exfiltration via exploited zero-day exploit.

The global financial impact is estimated in the billions, and it ranks among the costliest supply-chain breaches of recent years. Root cause investigation found the incident was tied to policy/procedure failures including insufficient secure-development and vulnerability-disclosure processes, delayed detection and patch-deployment procedures across customers.

UNFI (United Natural Foods Inc.) Disruption (2025)

Supply-chain outage with major economic ripple effects. The incident that crippled electronic ordering and distribution systems in retail systems Post-incident analysis highlighted insufficient third-party access controls, immature vendor governance, and inadequate contingency procedures for critical supply-chain IT systems. These policy gaps that allowed an intruder to escalate impact across retail partners and persist long enough to cause major business interruption and are estimated to cost hundreds of millions of dollars.

Colonial Pipeline DarkSide Ransomware Attack (2021)

Operational shutdown from compromised VPN credentials. The incident caused the pipeline to halt operations, producing fuel shortages and substantial economic and reputational damage. Root cause analysis identified policy and procedural shortcomings which included weak remote-access controls, lack of enforced multi-factor authentication for critical VPN access, and insufficient segmentation and incident-response playbooks for OT/IT separation.

Useful References, and Standards

“The good thing about standards is that there are so many to choose from.”

—Andrew S. Tanenbaum

There are several useful standards that affect IT and provide significant guidance to a security operations team. This section describes several of them.

Industry Reports and Organizations of Note

There are numerous resources which provide insight and analysis of attacker methodology, capability, dwell time, and behavior. They are listed in alphabetical order by the primary organization that produces the report or resource.

IANA

Institute for Applied Network Security is an industry advisory and consulting firm, provides access to some of the best in the security industry, and helps teams address and solve information, computer, and network security issues. IANS hosts over 100 end user security focused events, worldwide, per year.

Mandiant M-Trends Annual Report

This is based on a synthesis of real world cases. M-Trends provides real world statistical information on compromises, dwell time, and trends. www.fireeye.com.

Ponemon

Most known for annual **Cost of Data Breach** analysis, The Ponemon Institute has a wide variety of studies and research available. Much of the research is focused on current state issues facing businesses and IT, with some emphasis on healthcare. www.ponemon.org.

MITRE ATT&CK

MITRE Adversarial Tactics, Techniques & Common Knowledge (ATT&CK)

This is one of the best resources to understand how attacks progress from initial access through establishing persistence, lateral movement, and performing command and control. ATT&CK defines eleven major steps through the process. Under each tactic category are several examples of a technique used to accomplish that specific tactic. Each tactic has several example tools and mitigations for each of the tactics.

InfoSec Standards

There are numerous standards and references which can provide *significant guidance* for your security operations team, security architecture, and steps you can take to secure your environment. They

are listed in alphabetical order by the primary organization which produces the report or resource.

ASD

The Australian Signals Directorate maintains a list of 37 prioritized **strategies**¹⁴ to guide technical security professionals to mitigate cyber security incidents. Recently, these were updated and organized with the **essential eight**, or the eight high priority strategies. These strategies are listed by relative effectiveness security rating, user resistance, upfront cost, and ongoing maintenance.

CIS 18 Critical Controls

The Center for Internet Security maintains a set of eighteen **Critical Controls**¹⁵ that represent the most important cyber security actions any organization can take to improve their security posture. They update every few years based on current security threats and technologies. As of June 2024, the controls are at version 8.1. If your organization does not have a control framework, start with these, as they provide an on ramp to comply with PCI DSS, HIPAA, GDPR, and many other frameworks because every control fully maps to ISO 2700X, NIST 800-53. Also, with version 8, are adopting Zero Trust principles. The first two controls haven't changed that much since their inception, and for the SOC. They are repeated here from the website, so you can get an idea of what they say.

CIS Control 1: Inventory and Control of Enterprise Assets

Actively manage (inventory, track, and correct) all enterprise assets (end-user devices, including portable and mobile; network devices; non-computing/Internet of Things (IoT) devices; and servers) connected to the infrastructure physically, virtually, remotely, and those within cloud environments to accurately know the totality of assets that need to be monitored and protected within the enterprise. This will also support identifying unauthorized and unmanaged assets to remove or remediate.

CIS Control 2: Inventory and Control of Software Assets

Actively manage (inventory, track, and correct) all software (operating systems and applications) on the network so that only authorized software is installed and can execute, and that unauthorized and unmanaged software is found and prevented from installation or execution.

ISO 2700X

The International Organization for Standardization publishes a number of standards relating to information security. Most notable is the **ISO 27001:2013** and the inventory of security focused controls. The ISO controls provide an excellent library of measurable technical controls and is often the basis for an independent audit of an organization.

ISACA

Isaca is a worldwide professional organization that started with an emphasis on information security auditing, and has grown to cover IT Governance. ISACA is well known for Control Objectives for Information and Related Technologies. CobiT is a general IT management framework, not just a security framework.

NIST

The US National Institute of Standards has recently produced the Cybersecurity Framework which is a policy framework designed to help organizations assess and improve their security posture around cyber-attacks. NIST has also produced close to two hundred special publications relating to computer, network, and information security. One of the primary Special Publications is 800-53 v5, Assessing Security and Privacy Controls in Federal Information Systems and Organizations: Building Effective Assessment Plans. At close to 500pages, this document is written to facilitate security control assessments and privacy control assessments conducted within an effective risk management framework. Like the ISO 27001, this standard is often used as a basis for auditing an organization's security program and technical controls.

Use Ron Van O's SOC-CMMI and MAGMA frameworks

One of the leaders in the SOC/SIEM space is Ron Van Os. Ron has put together a CMMI based SOC assessment tool and a solid framework for developing **use cases**¹⁶.

-
- ¹ I would encourage not to blurt out in response to this question that that is “A Guaranteed Orange Suit Acceptance Posture”. It does not go over well.
 - ² <https://www.snort.org/talos>
 - ³ <https://www.proofpoint.com/us/resources/data-sheets/et-pro-ruleset>
 - ⁴ <https://www.snort.org/documents/registered-vs-subscriber>
 - ⁵ This section was significantly updated for BTHb:SOCTH V 1.01
 - ⁶ Customers and users. Customers are the persons or organizations who will approve and manage the project's product, service, or result (from PMBOK V5).
 - ⁷ Sponsor. A sponsor is the person or group who provides resources and support for the project and is accountable for enabling success (from the PMBOK V5).
 - ⁸ Stakeholder: an individual, group, or organization who may affect, be affected by, or perceive itself to be affected by a decision, activity, or outcome of a project (PMBOK V5).
 - ⁹ These are ITIL V3 Change Management terms.
 - ¹⁰ The steps are nearly the same done in the Business Impact Analysis (BIA) phase of a traditional Business Continuity Plan (BCP), and then the Disaster Recovery Plan (DRP). If your organization as a BCP, DRP, or TOGAF style EA team, then consult with them for the application and server inventory
 - ¹¹ For example, Advizor Analytics and/or Tableau.
 - ¹² From Offices.Net, August 2017.
 - ¹³ <https://www.td.org/newsletters/learning-circuits/time-to-develop-one-hour-of-training-2009>
 - ¹⁴ <https://www.cyber.gov.au/business-government/asds-cyber-security-frameworks/mitigating-cyber-security-incidents>
 - ¹⁵ <https://www.cisecurity.org/controls/cis-controls-list>
 - ¹⁶ <https://www.betalvereniging.nl/wp-content/uploads/FI-ISAC-Use-Case-Framework-Full-Documentation.pdf>

Chapter 2. SOC Access, Training, Skills, Staffing, and Roles

A NOTE FOR EARLY RELEASE READERS

With Early Release ebooks, you get books in their earliest form—the author’s raw and unedited content as they write—so you can take advantage of these technologies long before the official release of these titles.

This will be the 2nd chapter of the final book.

If you’d like to be actively involved in reviewing and commenting on this draft, please reach out to the editor at jleonard@oreilly.com.

Effective security operations teams require technical skills, should possess certain personality traits, and require product training by role. Staffing our SOC team is critical to success. It is important to understand that you cannot “make” ninja grade incident handlers and SOC analysts who can synthesize a dozen data sources in real time and find “the bad guy” after completing a one-week course and passing an exam. That type of skill only comes with “time in the game”. What you can do is develop people, provide them the opportunity to grow, and develop strategies to keep them in the Analyst seat. You can train people to respond to specific alarm types, handle specific cases, and work specific processes. There will always be “task driven” work that needs to be done by some level of SOC analyst. Playbooks make this level of staff effective, which in turn gives them success, and that leads to staff who want to do more. Those are the people you want to identify and grow.

SOC Access

SOC staff will need a variety of access grants to accomplish their job functions. Minimally, all SOC analysts will need access to the SIEM, case management, documentation repository and other core systems. There are many other systems though, that SOC will need access to that support their roles. Just like access to some systems on the network is segregated, SOC roles will need to follow the principle of logon segregation by creating a secondary account for elevated access.

Various SOC staff will need read access to many systems, will need tailored user access to several systems, and will also need some sort of “security auditor” role in numerous SaaS solutions and read access for cloud hosted log storage. For example, you may require that membership in an elevated role like Global Reader and Security Reader in Entra ID be granted through a secondary account, not because the user isn’t trusted, but because if they have those two roles with their day to day account and there is a compromise, those roles provide wide access to configuration data in Entra ID. There may even be cases where some SOC analysts need privileged access to implement a containment operation in near real time as a case unfolds.

Internet access is another area of concern. As a regular FTE, staff need general Internet access but as SOC staff members, there is a need for unregulated / unrestricted access for OSINT and malware research. A second use case is attempting to simulate or recreate an attack that occurred while a user took their computer off network, with the same degree of protection or lack thereof in place. Getting setup for this specialized use case can take quite a bit of work.

There are also reasons to use multiple workstations. For example, SOC staff should not be analyzing a malware sample on their system. Rather, there should be a method to safely get a sample to a dedicated analysis system like Lenny Zeltser’s RemNIX system running as a VM in a dedicated and protected enclave that has no reach back to the main network.

The SOC itself can also operate in a Zero Trust enclave, meaning that the SIEM servers, log collectors, and SOC systems are in their own network segment on a segregated VLAN, protected by a NGFW so that log data can come in, but not common attack vectors like allowing inbound SSH,

RDP, SMB/CIFS, etc. In this enclave, outbound internet access can be configured. However, as someone who has been in the game for 20 years, I advise that if you do, configure dedicated outbound access, install a NGFW with filtering that is on par with the corporate standard, and turn on full auditing. The telemetry value can be tremendous.

SOC Onboarding and Initial Training

Training for SOC will come in several flavors:

Product skills

These are actual vendor solution training. This is achieved through vendors offered on the SIEM platform itself or a major technology vendor such as the Cisco CCNA Cyber Ops program, because that course material targets the actual products in use.

Vendor neutral skill development

These skills should cover the job role, tasking, and concepts that the analyst needs *to do the job regardless of the technology platform*. There is no shortage of education available such as: college courses, certification courses like EC-Council Certified Security Analyst, ISACA's Certified Information Security Manager, CompTIA Network+, Security+, and CompTIA Advanced Security Practitioner; SOC focused training by SANS; and various Q courses offered by Security University. For readers in Europe, look into the European Information Technologies Certification Academy (EITCA) and European Union Agency for Network and Information Security (ENISA).

On the Job

Internal training relevant to the position and team, internally developed and delivered, playbook familiarization, and data landscape.

Success and Failure

There's nothing quite like "getting it right" and stopping the bad guy or missing the bad guy and finding out afterwards.

Cyber Range Operator training

Intensive exercises offered in a dedicated large-scale lab with a focus on hands on skill development.

And many more.

Your training program should include a mix of items from the items above, with the goals of ensuring that your analysts develop all the skills listed in the next section. As new staff are onboarded onto the SOC team, you should follow a well-defined structure in order to ensure that they will have the best possible opportunity to succeed. Below is a sample onboarding model for a SOC analyst I've used in several organizations. The primary goal of your orientation program should be to develop the analyst so that they can be self-sufficient at their level after four to five weeks through an onboarding program.

Table 2-1. Security Operations Analyst Orientation Example Schedule

Week	SOC Analyst Orientation
1	Organization onboarding Operator Level product specific orientation (usually 2d) Side by side observation by new person with a current analyst New staff reviews a “good” and “bad” write up (report) of each major alarm type that they will work at their level (OTJ)
2	Side by side alarm review and analysis – new staff works through alerts and is partnered with senior staff By the end of the week, new staff should be able to handle several alarm types on their own
3	New staff is introduced to more complex case types by reviewing “good/bad” reports, starts handling more of them More advanced product training focused on system health, uptime, and data flow monitoring Schedule time w/ each next level analyst/case lead to expand knowledge of various SOC areas
4	Shift and responsibility rotation – work various shifts Longitudinal “weekly” report contribution
5	Skills acquisition testing, which should consist of scenarios that support assessing how much the analyst has learned

SOC Analyst Skills

Historically, successful IR and SOC people need to have a diverse IT background, should have a few years in the IT game, do require continual training, and have a variety of skills to handle the breadth of cases a SOC will face. An analyst needs to understand how to “connect the dots”. Connecting the dots is a skill developed over time. Analysts can be educated on understanding a given data source but must acquire the skill to understand one event in context of another over time.

Analysts also need to learn how to efficiently preserve relevant case information as they work through an alarm investigation. An effective technique is to capture relevant data while they write a ticket or draft an incident report, instead of attempting to reconstruct data after an incident is over.

Modern cyber defense is based on several changes in the way that the Blue Team thinks about the adversary.

1. The presumption of compromise. This principle assumes that an adversary is already on the inside of the network and has, minimally, a foothold and an ability to access systems. The mindset shifts the focus to proactive threat hunting (actively looking at signs of adversary behavior.) Telemetry is focused on detection and reducing reaction time.
2. Defense requires threat hunting, which is discussed in a later chapter.
3. Implement an active defense posture, strategy, and practice. Active defense is a proactive strategy that involves actively taking measures to detect, analyze, and mitigate cyber threats, and not just relying on traditional, passive security like firewalls, web content filters, and endpoint antivirus.
4. Implement early warning sensors or indicators, also known as “honey-something” such as a honeynet, honey account, or honey record. These are all examples of active defensive measures.

5. Move from Red Teaming to Purple Teaming. In a nutshell, a red team attempts to penetrate a network, move throughout the network, lie in wait to see if the blue team detects them, and eventually gains access to the crown jewels. After working in several companies that have red teams, the author has found that many people do not do well with this approach. Regardless of the human impact, there is an even more insidious aspect to red teaming – many of the data sources that are needed to truly detect, analyze, and build a defense expire. The classic example is EDR data. If the Red Team hops from system to system over a 30-day period, then spends weeks writing a report, this critical data source is usually depleted by the time the blue team gets the read out. Instead, a much more productive and cooperative approach is to do mini tests and loop the blue team in within a day to review the successful event and build a defense, then rinse and repeat to see if detections work.
6. Focus detection efforts on post exploitation. When performing threat hunts, prioritize threat hunts so that the hunt team can find and confirm any sort of successful exploitation.
7. Behave in a response focused or driven manner for the threat hunting team and function. If hunters find evidence of a compromise, they should be able to act.

Below is an Analyst Skill Development Recipe which came from surveying over 30 SOC and Security Managers and then refined as I implemented that advice. SOC Analysts need to understand:

The “Attack” process and phases

Recon, Scan, Initial compromise, Establish Persistence, Command and Control, Lateral Movement, Target Attainment, Act on Objectives, Exfiltration, Covering Tracks, Leave without Trace. The MITRE ATT&CK framework is an invaluable learning tool in this space as well as the Cyber Kill Chain.

Ethics

Ethical behavior means that they work within their limits, ask for assistance, do not overstate conclusions, never fabricate an opinion on weak facts, keep confidential all of the data they use, and other professional responsibilities.

Organization specific data familiarity

Familiarity with your organization's source data (event types and fields) so analysts can tease out fact data that can "connect the dots" to the alarm event in the overall context of the event stream for the suspect machine or user. *This is one of the hardest skills to develop.* As a new data source is added into a given system, engage the EDIS process: the senior level analyst must prepare an overview of the data for the remainder of the team.

System

Technical system access control capabilities and how technical control can be applied.

Firewall

Firewall Principles such as log types and what the log row records; rule attributes; actions such as block, allow, reset, drop silently; interface meaning as it relates to flow; SNAT/DNAT, byte sent/received; and understanding security zones.

Security zones

In particular, security zones are specific to each organization. One can infer the meaning of a zone but should not because a zone term may not be consistently applied by the various admins or engineers. As firewall rule sets are built, the firewall team must document what they mean by a given zone and their underlying assumption about traffic flow. Active Directory and Entra ID/Azure admins need to do the same thing for organizational unit definitions. In this way a firewall zone named "eComDMZ" can be connected to an ADOU named "WebSalesDMZ" when the definitions state "servers used to support web sites used for ecommerce".

PCAP collection and analysis

Network data collection and the use of tcpdump as the data collection tool and then Wireshark/TShark as the analysis tool.

Forensics

Forensic principles

- Gathering data on system following the order of volatility
- Establishing and maintaining Chain of Custody
- Documenting actions taken, data extracted, time shift, and timeline reconstruction
- Locard's Exchange Principle

Hardware

Hardware platform: Foundational knowledge of a PC, Server, Router, Switch, TAP, disk boot, MBR, and identifying volumes.

Incident Handling

Incident Handling process: Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned. Once someone understands these points, they need to be able to work through the core processes, communicate with a variety of people to work a case, and write an executive summary of an alert .

Investigation

Investigative processes as described in the Alarm Investigation chapter.

NAT Issues

Nat translation and the complexity of locating the true source IP.

Network Application Protocols

Dns, SSH, HTTP/S, SMB, NTP, DHCP, FTP, SSL, SMTP, POP3, IMAP, and SIP.

Network Protocol understanding

Icmp, QUIC¹, IP, TCP, UDP, GRE, BGP, SCTP, and ARP.

NIDS

Network Intrusion Detection System (NIDS), ruleset categories and how to read events generated by an IDS using rulesets such as the Talos Snort rule set (formerly known as SourceFire VRT) and the Emerging Threats Pro feed.

Application Portfolio

Organization Application inventory, application behavior, and PoC's

Policy

Organization Policy/Procedure and the ability to politely articulate and enforce PnP.

OS proficiency

Windows and Linux: services, startup, log files, network connections, registry, and process identification, and how rights and permissions are applied to both Windows and Linux.

Scripting

Programming, focused on admin and data reduction scripting skills using PowerShell, Python, shell, Perl, or a similar utility focused scripting language

Report writing²

Including spelling, grammar, Word usage, and the ability to write a summary that answers “Whom, What, When, How, and Where”, and make a reasonable assessment of “Why”.

HTTP, HTTPS, and Web Browsers

Understanding how the most dangerous application, a browser, works is critical to analyst success. The application itself is more commonly attacked than the perimeter, because it is more successful. As evidence, consider the rise in phishing tools and attention on social engineering the end user to entice them to click. The ability, and consistent habit, of identifying the source user when a proxy server is involved in an alarm is essential. When an alarm occurs or a proxy is identified as participating in an intrusion, the analysts need to always attempt to find the user, user agent, or system that generated the traffic.

- Understand user agents, HTTP status codes, URLs, and browser redirection.
- Research the URL data revealed through the proxy.
- Discretion when researching user browsing habits.

OWASP Top 10

Following on the need to understand the browser is the need to understand how an Internet facing application is attacked.

Cloud Authentication processes

Saml and Ouath authentication, MFA enrollment, and identity proofing because identity is the new perimeter.

All the skills measured

All skills measured in the CompTIA Security+ certification and many of the Network+ skill areas so that a SOC analyst is terminology compliant.

SOC Analyst Traits

SOC Analysts need to have specific personality traits to be effective at their jobs, as listed out below.

Natural curiosity

Soc Analysts will be faced with an ever-changing array of problems, situations, and new data sources. Find people who took things apart and put them back together when they were young, especially if it worked when they were done.

Organizational skills

An ability to perform “rapid research” that allows them to separate wheat from chaff, and in particular the ability to determine if an alarm is likely to be real, based on the alarm and data surrounding the alarm. For example, if a NIDS rule fires from an attack that was popular three years ago, what conditions must exist today to permit that attack to succeed?

Abstract thinking

In particular, the ability to read intrusion events like alerts from a Snort/Suricata system and a Palo Alto firewall and correlate them in near real time to other data sources, visualizing activity patterns in their minds.

Contextualize large data sets

The ability to reduce a larger volume of data down into information, in context. More specifically, when faced with an alarm *right now*, determine if that alarm is relevant to a larger context.

Communication

Perform data summarization and commonality detection such that a group of original facts can produce information and then articulate how the information proves or disproves a hypothesis.

Ego

A small ego, but not small enough that they don't take pride in their work.

Defensive mindset

Have a defensive mindset or frame of mind and understand defense in depth with a working knowledge of IT systems and TCP/IP

networking.

Strong attention to detail

Have a strong attention to detail, can “connect the dots”, and lastly who can perform research.

SOC Roles

There are several roles that need to be staffed in a security operations center. Depending on the size, scope, and budget, a SOC may have more defined roles. Roles will also have defined interactions with other key roles, because a SIEM platform and NSM platform have user community – the SOC analysts – who are supported by the engineering, architecture, and process support side of the SOC team.

Table 2-2. SOC Roles and Functions

Role	Duties and Responsibilities
Analysts	As defined in SOC Layered Operating Models, this role is the primary SIEM, NSM, and log management system user. Analysts may function as incident handlers or may directly support the CSIRT function.
SOC Developer	There will be a need to write “utility” software, such as a log parser, a monitor script, an add-on component for a dashboard, or a lookup tool. Many SOC’s would benefit from being able to utilize development talent and skills.
Shift Lead	A senior analyst who ensures that all shift responsibilities are met and is a resource for SOC analysts. Shift leads also handle communications external to the SOC, and therefore should have well-developed people and communication skills.
SIEM Engineer	Engineers install, maintain, and upgrade the SIEM platform and its operating systems. They also implement use cases, provide troubleshooting, and configure device support. Advanced SIEM engineers can also build parsers for unsupported devices, which usually involve knowledge of regular expression parsing and SQL queries. Lastly, a SIEM engineer needs to document the EDIS process and prepare internal OTJ training for all SOC staff so that analysts properly interpret event data.

Role	Duties and Responsibilities
Security Process Engineer/Analyst	A process engineer has a security focused system analysis role. They perform analysis to develop, define, and test use cases, train the analysts on supporting use cases, and help to develop reports.
SOC Manager	This is a day-to-day managerial role for the SOC team. The primary customer is the CISO. The SOC manager implements strategy and process defined by the CISO.
CISO	The CISO owns the information security management program. The SOC team, SIEM, log management, and NSM platforms support many aspects of the program, such as incident response, continuous monitoring, and log management. CISO's must understand business requirements and expectations (without this understanding, they are likely to fail).

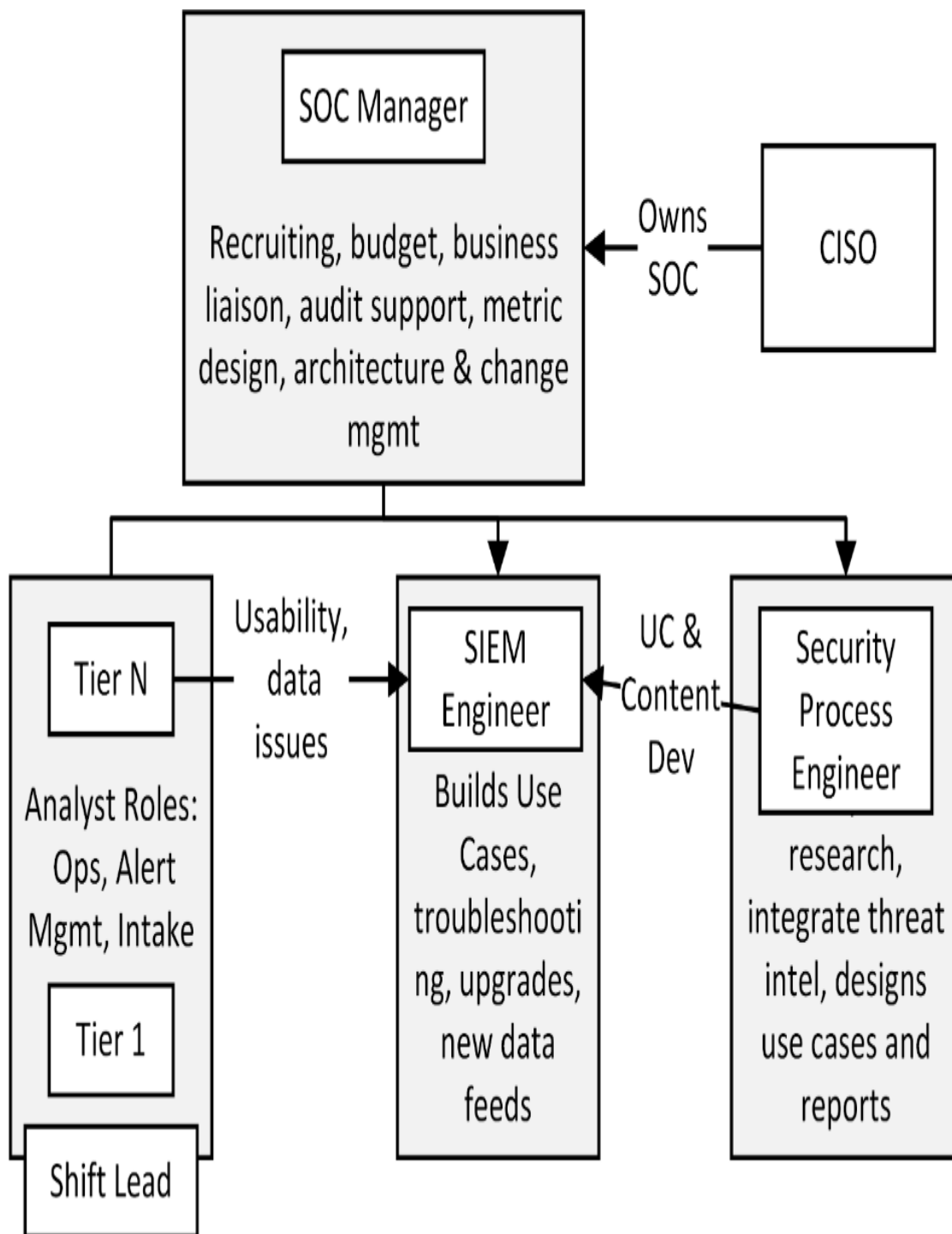


Figure 2-1. SOC Roles and Relationships

SOC Layered Operating Models

A small security team of just a few people rarely follows a hierarchy. The team may just work with each other to monitor the environment and respond to alarms, may have defined roles that handle specific case types, or have a layered structure. As a Security Operations Center

matures and grows and breadth, it usually develops into some form of a tiered analyst job structure that reflects staff skill base, alarm conditions that are worked, pay level, SOC service areas they support, and training commensurate with their job level.

This section describes two different approaches: a two and three-layer approach, with the word “layer” being used as a placeholder. Job titles may be Tier 1 Analyst, Tier 2, and Tier 3 Senior Analyst, or titles like Junior Analyst, Analyst, Senior Analyst, Lead Analyst, or SOC Shift Lead. Regardless of the actual title, the essential concept is that there are layers that relate to the analysts’ skill base, comfort level, and their ability to respond to alarm and event conditions which in turn ties to pay and responsibility. Layers models also provide a way to measure progress and provide job advancement by title and pay commensurate with the skill base. Regardless of the model and title, there is almost always a formal management layer for the Security Operations team.

What is essential to whatever stratification model your SOC uses is that each analyst must be willing to ask for help if they find themselves outside of their depth when working on an alarm or handling a ticket.

Two Layer Model

In a two-layer model, the front-line staff is most often staffed with trained security analysts while the second layer is staffed by a senior staff level staff who handle more complex cases, run incidents, or take on more complex analysis. Above these two operational layers are SOC management staff. Each of these levels will have end user and management interactions at some point.

Table 2-3. SOC Two Layer Model Roles and Responsibilities

Layer	Example Duties and Responsibilities
1	Real time event and alarm monitoring that follows a standard operating procedure for a wide variety of alarms Phone intake for initial case support (phone, email, webform) Run reports Monitor SIEM system health, data feed checks, and keep an eye on the system(s) as a whole Gather key data, feed many case types to the ServiceDesk, handle and process more straightforward alarm conditions. and escalate more difficult or complex cases to the next layer <i>after</i> they have collected some initial data Close some cases based on well-defined criteria. Certain analysts may be asked to perform “longitudinal analysis”.
2	In depth analysis of alerts and events escalated by Tier 1 Perform complex analysis and research on alerts and events, such as previously unseen alarm condition from a new data source Take a longitudinal view of event patterns, searching for longitudinal security issues Coordinate incident management Tendency to specialize in certain alarm types, systems, or areas of the business Synthesize vulnerability data Performs daily or weekly threat hunting activities

Three Layer Model

In a three-layer model, responsibilities are more stratified as the organization attempts to respond to increased need for more coverage and balance with staff costs and skills or a need to provide more coverage like adding in overnight and weekends. Therefore, a higher separation appears to enable junior analysts to be effective for the SOC.

Table 2-4. SOC Three Layer Model

Layer	Example Duties and Responsibilities
1	Real time alarm monitoring, using a well-defined SoP or other standardized Operational Guidance document Phone intake for initial case support (phone, email, webform) Monitor system health and data feeds Gather key data, escalate most cases to the next layer if they can't resolve the case quickly or close some cases based on well-defined criteria.
2	Handle escalated alarms In depth analysis of alerts with a determination whether to forward or not to Tier 3 Review the inventory of daily event types received by day, looking for patterns that may indicate a security issue Take a short-term view of event patterns in support of alerts (a higher degree of alarm awareness) Support incident management data requests Tendency to specialize in certain alarm types, systems, or areas of the business Perform data feed monitoring and basic system daily checks Synthesize vulnerability data Perform daily or weekly threat hunting

Layer	Example Duties and Responsibilities
3	In depth analysis of incidents and cases, individually, by day, or longitudinally Manages incidents, may function as an incident coordinator/commander, or may be a second in command Take a longitudinal view of event patterns in support of alerts and areas of the business or a client Has operational and longitudinal responsibility for specific areas of the business, or a client area/business unit Performs specific daily threat hunting activities Capable of performing memory or dead disk forensics, or may supervise outsourced forensics

SOC Maturity Curve Using the CMMI

Security teams go through a variety of growth phases and stages, which often happen very organically. SOC's usually start when management hires someone either deliberately or as a response to an event because they need to "get a handle on security". That first hire then hires or pulls in a few people from IT to form the security team, and as a natural outgrowth some form SOC team is formed. Muddled in these organic steps is a focus on "buying and implementing a SIEM", which gets funded as a project³. Then you have a SOC in someone's shared office, or a couple of people get some space in the Network Operations Center (NOC). All of this happens while the people involved are doing their "day job".

These types of organically grown teams often miss a critical factor in their formation: the SOC function wasn't deliberately created following a needs assessment or a formal model. As a result, varying aspects of SOC services operate at different levels. The SOC staff members write different reports in response to the same alerts so results are not predictable, everyone has different skill levels, the operational structure is not internally consistent, and staff may be frustrated.

How is this problem solved? One well-respected method is to apply the Carnegie Mellon Capability Maturity Model Integration (CMMI). There are five maturity levels across in the CMMI, with each level representing an evolutionary plateau in terms of process improvement. Normally, CMMI is applied holistically in an organization across up to twenty-four process areas, so using it needs to be adapted and focused for a Security Operations organization. *It may not be necessary, or even desirable,* to push all capabilities and processes to level 5, because each maturity level is measured by meeting a set of objectives for the process.

Table 2-5. CMMI Five Level Maturity Model

Name	Characteristics ^a
1: Initial	Processes are ad hoc, chaotic; success depends on heroics as opposed to following a defined process. Services often work but exceed budget, time, schedule. Success is not repeatable, and heroic action frequently saves the day.
2: Managed	Workgroups (the SOC) define processes, create work plans, monitor their processes, and meet a set of “contract requirements” with its customers (the business). Configuration management is implemented with quality assurance.
3: Defined	Defined processes for managing work are used, well understood, services, procedures, tools in place. Sound project management is implemented into each process set. Difference in L2 and L3: process/procedure can be quite different in each instance of the process, whereas L3 procedures are tailored for the workgroup.
4: Quantitatively Managed	There are quantitative objectives for quality and process performance, which are used to manage processes. Measurement statistics are collected on specific subprocesses. Difference in L3 and L4 is focused on predictability.
5: Optimizing	Focused on continuous improvement.

^a These points are adapted from the SEI CMMI for Services, 1.3. Note that as this book was written, 2.0 was just released, so you should review 2.0 material. 1.3 URL: https://resources.sei.cmu.edu/asset_files/Webinar/2010_018_101_22253.pdf (8/16/18)

There is also a formalized model available to assist in assessing the SOC's maturity level. The SOC-CMM was created by Rob van Os, MSc. as part of his master's thesis work⁴. Rob's methodology, tooling, and spreadsheet is set up to evaluate the SOC across five dimensions and twenty-five aspects. The five domains are Business, People, and Process, which are evaluated for maturity. The other two are Technology and Services, which are evaluated for both maturity and capability. You can use this tool to evaluate your current state and develop a road map of how to mature your SOC. Rob's site is <https://www.SOC-cmm.com/>. Rob's tools are gaining quite a bit of traction.

Measuring Data Source Integration Maturity Levels

To apply the CM CMMI, the SOC can consider how it integrates a data source into the SIEM and its operational process as a process that must be well managed and repeatable. As a primary requirement, in order to move that ad hoc process to a mature well-defined process, the SOC needs to systematically accept data, mine that data, and ensure that the SIEM platform is maximized to the fullest.

Data Input as an Initial Process (L1) is characterized by:

Getting data into the SIEM can be very ad hoc. A well-meaning system custodian sets up a syslog feed and lets SOC know that new data is arriving.

Someone in SOC works with a system custodian to make sure that the system's data can be gathered into the SIEM.

Someone else in SOC works with the SIEM vendor to make sure that data is parsed.

Data survivability baseline is established so that if the source system stops providing data, it can be detected "quickly enough."

Data Input as a Managed Process (L2) is characterized by:

Data input goes through a consistent process. Source system instrumentation is well defined, if there is a need for custom by the

vendor it is planned, and a synthetic transaction is setup (see p.).

The source system is fully exercised so that all the security and operationally relevant events are logged.

Once the data arrives, SOC builds source specific alarm conditions based on that data source.

The SOC is trained on the breadth of event types so that the team can fully utilize all of what the source system can provide.

Data Input as Defined Process Characteristics:

Organizational policy and process artifices require that data source input is integrated into the organization. For example, policy requires logging to the SIEM and/or log management platform is required, and a check to see if this is setup properly is integrated into the Configuration Management process.

The SOC manager ensures that all users have completed onboarding for each data source and confirms that there is equivalent understanding of how to use security and observability event data.

Measuring Alarm Processing Management Maturity Levels

To apply the CM CMMI, the SOC can analyze how it handles Alarm processing. Alarm processing is another good example of a service that should be consistently delivered. This service is the result of processing data input into the SIEM and then acted on by the SOC analyst. In order to realize this service, all aspects of the SIEM and SOC are part of the service delivery: data input, parsing, health monitoring, alerts raised in response to events, analysis of alerts to validate that they are true positive, severity is responded to, based on the impact to the organization, incident response is activated to the degree needed, and the resulting incident is tracked through to resolution.

That is quite a mouthful! Below is an example of how alarm management can move through a set of maturity steps, going from an ad hoc maturity level to a well-defined level. The primary requirement is

that the SOC read, review, and respond to alerts as rapidly and completely as possible.

Alarm Processing as an Initial (L1) Process has these characteristics:

SOC Analysts review alerts as they arrive, with some notion of priority and impact. High priority alerts which are likely to be true positives receive attention such as reporting for resolution, data owner and system custodian notification, or routed to Tier 2 for further investigation.

SOC analysts may or may not be consistent with each other in the decision-making process on alarm resolution. During times of high stress, alerts are not consistently managed. Critical alerts may never be evaluated in a timely manner.

Alerts may occasionally be reviewed daily in the aggregate such that critical alerts always receive some form of treatment as a “stop gap”.

Alarm Processing as a Managed (L2) Process Characteristics:

Event data is reviewed in order to find other alarm conditions in order to improve detection capabilities.

Alerts are tuned so that false positives can be minimized. This part of the process should influence the source system in a feedback loop.

Alerts are treated consistently by all members of the SOC, with most of them mapped into incident playbooks or other supporting processes.

Alerts are resolved, routed, or investigated as they arrive within a certain defined time frame – say 30 minutes for critical, one hour for medium, and within 4 hours for low.

The alarm board is reviewed every shift to *ensure* that all “Critical”, “High”, and “Medium” alerts receive attention.

Alarm analysis and processing enter a tuning process so that lessons learned and system custodian feedback improves the alarm management process.

Alarm Processing as a Defined (L3) Process has these characteristics:

As data sources are integrated into the SIEM and SOC processes, they are mapped into the taxonomy, the review processes are defined, and the

SOC staff are fully trained on the data source and the alarm conditions it brings to light.

The SIEM platform is augmented with orchestration and automation to improve analyst responsiveness and put better data in the hands of the analyst.

Alarm and Event data is used to guide a threat hunting program, and the threat hunting program in turn guides and improves alarm generation capabilities with the corresponding SOC processes.

Example SOC Turnover Shift Check List

Start with this list for your shift-based SOC turnover process. Cover turnover at the beginning of each shift. Each shift needs to summarize running alerts, incidents, and follow-up items for the following shift as these are critical for situational awareness. Review this list and define what analysts do per shift, develop an organization specific model, and then update the end of shift turn over. Some SOC teams aren't staffed enough to provide an overnight function, so at the beginning of the morning shift there should be an immediate review of overnight alarms. Determine how to incorporate this point in your environment.

1. Turnover from prior shift, which should include:
 - a. Key events
 - b. Status for ongoing incidents
 - c. Staff outages
 - d. Major data issues
 - e. Any system stability issues
 - f. Relevant communication topics
2. On the normal maintenance day, review the scheduled changes so that the SOC won't over react for alarm conditions that can be explained by a change running through change management.

3. Quick review of yesterday's alerts so that any recurrence or repeat conditions which may reveal a repeat event are easily identified.
4. Review the daily briefing, which should cover topics like:
 - a. New alerts implemented in the system
 - b. Data sources leaving the system
 - c. New data sources coming into the system
 - d. OTJ training gaps

-
- ¹ Quick UDP Internet Connections, a protocol promoted by Google that supports multiplexed connections between endpoints and is supported by almost 1% of web servers (August 2018).
 - ² Chris Sanders has the only course the author knows of on this topic.
 - ³ Remember – a project is a one-time event while running a security operations team is an ongoing business and IT function. They are very, very different.
 - ⁴ The SOC-CMM is available at Rob's website: <https://www.SOC-cmm.com/>

Chapter 3. Metrics for the SOC

“What cannot be measured, cannot be managed.”

—W. Edwards Deming.

“Not everything that counts can be counted, and not everything that can be counted counts.”

—William Bruce Cameron

A NOTE FOR EARLY RELEASE READERS

With Early Release ebooks, you get books in their earliest form—the author’s raw and unedited content as they write—so you can take advantage of these technologies long before the official release of these titles.

This will be the 3rd chapter of the final book.

If you’d like to be actively involved in reviewing and commenting on this draft, please reach out to the editor at jleonard@oreilly.com.

Mature business operating units and enterprises utilize various methods to measure the operating units effectiveness. The SOC is no exception. The question is how do you get there and avoid toxic metrics that demotivate your staff? How do you justify your budget, and measure your ROI? How well is the SOC doing in its daily operations? Does the SOC suggest, contribute, and build its own improvements?

In the book *Pragmatic Security Metrics*, W. Krag Brotby and Gary Hinson make several key points about metrics. Some of their key definitions are listed here from **Chapter 1.6**:

1. Instrument: short for “measuring instrument,” that is, a device for measuring.
2. Measure: (verb) to determine one or more parameters of something.

3. Metric: a measurement in relation to one or more points of reference.

In Section 2.6, Brotby and Hinson state “Having valid metrics enables business managers to make rational, sensible, and, for that matter, defensible decisions about information security. No longer must they rely entirely on advice from information security professionals or generic good practice standards, laws, and regulations.”

Section 3.2 makes these points: “Metrics are primarily a decision support tool for management. Good metrics provide useful, relevant information to help people—mostly, but not exclusively, managers—make decisions based on a combination of historical events (the context), what’s going on right now (including available resources and constraints), and what is anticipated to occur in the future (the change imperative).”

There are numerous metrics and measurements that can be developed and applied to a SOC. When it comes to designing a metric, there are several criteria.

Take these criteria into account as metrics are developed.

1. Metrics should be relevant to the goals, objectives, and the mission of your SOC as a business unit. This means you should be able to describe what you do numerically and also explain what you don’t measure.
2. As you evaluate your data, security use cases, and metrics, be sure to develop a roadmap of what you will measure, how those measurements will be captured, the tie-in to the IT General Controls and security program, and the business value chain where possible. Metrics can then provide guidance for decision making. The calculation method of any metric should be clear since the method for calculating a metric can vary.
3. Be sure that what you are measuring will drive towards a measurable outcome. Don’t measure for the sake of measuring. Every metric should inform a consumer and seek to either to change behavior or demonstrate that current behavior is operating well within established procedures. Here, you should

be clear on any action that you expect a consumer of the metric to take based on the measurement.

4. A metric should support a “control” and therefore should match up to your ITGC program. If you do not have an ITGC, look to standards like the ISO 27002.
5. Bad data is marginally better than no data at all. If you are not collecting any source data for what you need to measure, start there, but do not stop. Use good data to its fullest.
6. Avoid burdening the analyst with the need to record an excessive amount of detail using some artificial means to track what they do like a complex spreadsheet. Instead, develop methods to mine the SIEM platform, the workflow or ticketing system, SOAR platform, opening investigation coding, and alarm closure codes as they work through alerts. These methods provide an *economy of mechanism (EoM)*, *because the analyst is using their native tool*. Also, following EoM principles pushes you to consistently leverage an internal capability of the SIEM platform, the less likely you are to cause mistakes.
7. Tell your story in terms of your business / organization. When telling stories, it is very important to remember the audience and use terms and definitions that they will understand.
8. Two key acronyms come to mind:
 - a. Be SMART: Specific, Measurable, Achievable Relevant, Time-bound
 - b. KISS, or Keep It Simple, Sam/Susan. This isn’t meant to be cute. Rather, ensure that the name of the metric and the measurement scale is obvious. A metric that requires explanation is not likely to be an effective metric.
9. Determine how you can build a score card that measures the information and technical security posture of your organization. Whenever possible, build a tool to demonstrate how effective

the technical tools work. You may not show this tool to management – but you should be ready to.

10. Work hard to avoid any toxic metrics, which are one that can end up punishing someone who “doesn’t close alerts fast enough” or “only works on five cases per day”. Instead, focus on metrics that are objective and will advance the mission of the SOC.

In the table below, MTT means “Mean Time To”. There is an inherent assumption in a mean that what is being measured occurs frequently. It may take quite some time for some of the events behind these metrics to occur often enough to generate an arithmetic mean. You may need to modify the idea behind these measurements to occurrences per year or last time when something the event happened until your program has had enough run time to develop enough data points.

Table 3-1. Example General SOC Metrics

Metric	Definition and Notes
# Unique Data Source Types providing SIEM data	Defines how many different information system data source types are consumed and available for analysis. This measures how many of your technical systems and applications are instrumented. There is a corresponding percentage of coverage in unique sources / total sources, which will be a moving target.
MTT Detect Data Source Issue	How long does it take to detect that a data source is not functional, which is affected by the volume and velocity of data arriving from the data source?
MTT Correct for Data Source Issue	How long will it take to resume data delivery once an error is detected in data delivery? This is often measured in days.
Time to sweep the enterprise	The Security operations function should be able to check every host in the enterprise for IoC's, or the host's security state. Ideally the average time to interrogate operating systems, servers, and workstations enterprise should decrease over time, and the percentage of completeness should increase (# investigated / total #). Sweeping the enterprise is often done with an EDR platform. You may not have 100% coverage for a wide variety of reasons, so some alternatives will be needed.

Metric	Definition and Notes
% of apps under ALCE ^a monitoring (Non-AD Integrated)	Measures how many shared applications report account life cycle events. Metric assumes that the app inventory is known. Applications that defer the central directory either through native integration or LDAP query <i>are counted</i>. Desktop apps are not normally included in this metric – only shared, server based, or SaaS applications. This metric has an <i>implicit assumption: you don't need to measure applications that are AD integrated for ALCE events. You will need to validate this premise for your own organization.</i>
% of SaaS under periodic ALCE monitoring	Integrating SaaS into a SOC or a SIEM can be problematic. As a compensation and at a minimum, all SaaS applications should be periodically reviewed to ensure that users defined in the application both have accounts in the central directory or can be accounted for, and that there are no disabled organizational accounts which are enabled in the SaaS application.
MTT Close an alarm by Close Category	Measures the decision-making process by the SOC analyst to close an alarm when it can be explained, processed, escalated, is non-reportable, or non-actionable (example close codes). WARNING: This metric and ones like it can easily become toxic to your staff. Be very careful in adopting this metric. Instead, we should search for alternatives to show that the staff can effectively respond to a portion of alarm conditions daily.

Metric	Definition and Notes
MTT Forward an alarm up Tier	Measures the lowest level analyst response time to identify that an alarm requires further action or resolution by the next level analyst or application SME.
MTT Open a formal Incident	The SOC function may open a formal incident at any point in the alarm review process. This measures overall SOC and Incident Response team's capability to detect that an alarm or another condition is indeed a "security incident".
MTT Implement a use case	Measures how long it takes to define, document, instrument, and train on a specific SOC Use Case as defined Chapter XX.
# of Implemented Use Cases	Each organization will have a defined set of security conditions that SOC is able to handle with a supported use case or a response playbook. These metrics measure SOC capability and coverage. Cautions: do not count the number of "detections" from your SIEM platform, or "alerts". Rather, take those into account and define your SOC playbook. This metric also guides how much training is required for new analysts and how well you are doing at mining your source data. Also, "# of "new" event conditions converted to Alerts can count here but may not warrant a full use case.

Metric	Definition and Notes
# of Use Cases (rules) that never fire	While it is true that you can create, and test, a notification process for a rare condition, the SOC should keep an eye on use cases that never cause an alarm over a reasonable period, say one month. Try to keep use cases that never fire minimized. As described in the Detection Engineering chapter, you should implement a “synthetic transaction” for each rule that supports a use case to be sure that the rule works on some periodic basis (monthly or quarterly).
# of Events Received	As a raw number, this metric isn’t tremendously valuable. A better number is to measure events by severity, priority, or criticality – and don’t get confused here. There is a companion metric – TB or PB of storage consumed.
# of Alerts by Severity	Based on a combination of your SIEM platforms in use, and the ability of developing a holistic severity level.
# of high severity alerts not reviewed after 8 or 24 hours.	Measures how well SOC does at putting attention on all “high severity” or “high priority” alarms, per shift, and per day. If the frontline analysts cannot keep up with alarms, then consider adding more staff, improving automation, and put attention to defining “close/escalate” criteria on these alarms. Once done and under control, this metric/measurement would push down the severity levels.

Metric	Definition and Notes
Rules Tuned to Minimize False Positives (per week/month)	Every SOC should have at least one staff member who spends some time improving the notification rules within the platform. The better a SOC tunes the platform, the better it is demonstrating understanding of the environment.
ATT&CK Coverage by Phase	The MITRE ATT&CK matrix is a knowledge base for understanding adversary behavior and the attack life cycle. This matrix should be used to evaluate how many detections and log sources exist by ATT&CK tactic so that you can identify and close detection gaps. The objective is to ensure that the SOC and current instrumentation can identify the presence of an attacker on the network based on the activity defined in the ATT&CK framework.
Alerts per Analyst	Measure total alarm volume divided by available analysts per shift or per day.
False Positive Rate	As alerts are raised and reviewed many of them will be declared a “false positive”, or more colloquially known as a “nothing burger”. This measurement is <i>inherently different and should not be confused</i> with “explained activity”, which is entirely a different measurement.

Metric	Definition and Notes
# of Alerts resolved as Explained	Alerts are designed to find adverse conditions or threats and it is often true that once the alert is investigated, it can be explained by activity. As an example, clearing a Windows event log (Security/1102) is a well-known indicator of malicious activity. When this is investigated and the person who cleared a log can explain why, the alert is ‘explained activity’. We want this, because it shows that if an adversary performed an action, the SOC would have caught that action.
Playbooks with Automation and playbook coverage	Many SIEM platforms have a SOAR component. These can be simple to complex. The more automation that is built into a playbook, the more time available to an analyst to hunt, react, or perform more analysis. As an example, many organizations implement a “kill switch” operation if a user account is compromised to shut that account off on the VPN, in the account directory, and in any “account authentication islands” that don’t use the central directory. If there are five systems that are involved and all of them have an automated “disable the account” function, that is highly valuable because it means that the analyst themselves does not need to arrange for the “disable” action, the SOAR platform automates that.

Metric	Definition and Notes
Threat Hunt Yield Rate and Volume	These measurements quantify how often a threat hunt reveals malicious activity and then how many systems or users had that activity. The threat hunt team proactively looks for signs of compromise, and they usually do this and track a specific “hunt”. They may do 1 hunt per day, or 5, depending, and that is one measure. The second measure is how many affected systems or users are found, which is usually measured “per hunt”.
^a ALCE: Account Life Cycle Event	

Incident Response Metrics are not the same as SOC metrics because they pick up where alarm processing ends in many cases. In other words, when the SOC identifies a true incident, they will turn that over to an Incident response function.

Table 3-2. Example Incident Response Metrics

Metric	Definition and Notes
Cost per incident	There are two dimensions to cost: One is an accumulation of non-FTE cost contributions, such as paying for credit monitoring during a data leakage event. The other is the number of FTE hours lost.
MTT to Detect a Security Incident	How long does it take for the SOC to review an alarm and determine that it is, in fact, some sort of incident? For each incident attempt to measure the difference between the alert generated time, the Activity started time, and when an analyst determined that the alert is a true positive and an incident has occurred. Report the daily average and median
MTT for Detect to Contain	Once a security incident has been verified, several steps are taken to determine how to “stop the bleeding”. Some issues can be easily contained, such as removing an infected single computer and replacing it, some cannot, such as changing the codebase for a complex application.
MTT to expel an intruder	Once a true intruder is identified, meaning a real adversary, how long does it take for the security team <i>as a whole</i> to push the intruder out of the network. Be careful to analyze and report this correctly for your environment to ensure that consumers understand that there are more decision makers than just the SOC involved in this metric.

Metric	Definition and Notes
Incidents opened and closed	These should be trailing numbers, meaning as incidents are opened there should also be incidents being closed. These are measured per day, week, and month.
Avoidability of an Incident	Incidents should conclude with some form of Lessons Learned function, meaning that because of an incident the security posture of the organization is improved to the extent possible. If it is determined that the incident was avoidable if a common security practice was in place, report it.
Thoroughness of eradication practices	Measures whether the original compromise event, or one that is substantively the same (like a remote exploit) is observed subsequent to the first occurrence.
MTT Notify Principle, System Owner, or Custodian (Incident metric)	The recipient of an alarm condition may be a little hard to track down. There are at least three possible recipients – a principle within the organization, such as an operational director responsible for the affected system(s), an actual designated system owner, or a custodian such as a system administrator. SOC should define its escalation points and determine how to measure how well and quickly it communicates to the designated recipient.

Risks and Tradeoffs for SOC Metrics

As you develop and refine measurements for your security ops team, avoid chasing raw fsspeed at the expense of signal quality. Instead, prioritize detections and measures that reduce real risk, focus ATT&CK

coverage on high-impact techniques with validated telemetry, and treat telemetry/timestamps as first-class data, meaning verify them daily.

Focus on what matters most. At the highest level your goal is to have high quality detections and use cases that bring genuine security alerts forward, those alerts get triaged and worked based on risk. For example, what is the business impact? Does the alert relate to a single non privileged individual contributor, or a highly privileged account that shows signs of being controlled by an adversary?

Next, ensure that you can make sure that analysts gather enough data and signal early on for alerts to determine if there is an incident or not. Empowering and enabling that decision making process should get incidents worked as early as possible.

If you tune rules to reduce MTTD and MTTR, false positives are likely to rise because detections are broader and analysts need to weed out something real from something false. Track the false positive rate for a given alert, alerts per analyst, and time to triage. If these rise, then the alert itself needs to be tuned.

A second issue is pushing for 100% ATT&CK coverage. This is just not practical because the cost of collecting, building, tuning, and maintaining some method to every technique has diminished returns. Instead, focus in on what matters most – command line activity, account life cycle, data source coverage, and other methods that bring adversary behavior forward. Make sure that you have coverage of the value chain.

About the Author

Don Murdoch, GSE #99, MBA, MSISE has numerous GIAC certifications as well as being a TOGAF Enterprise Architect, SABSA Chartered Architect, and a CISSP with the ISSAP concentration. Don is a thirty-year veteran of information technology. More than half his career is devoted to information, computer, and network security. Don started his career with a boutique contracting firm located in eastern Virginia, writing COBOL and FoxPro code. For the next twelve years, Don took on role in a different aspect of IT as he grew his career: managing a small network, writing old school Perl/CGI software, developing international billing software for a startup ISP, and managing IT for an Application Service Provider right at the time of the Dot Com bubble burst. Don transitioned into information security where he started a DRP practice for an IT commercial spin off from a television production company. Things started cooking when Don entered his “digital combat training” phase in the “Wild, Wild, West” of academic computing for one of Virginia’s largest institutions for higher learning. Don wrangled bots, tangled with well-equipped adversaries, and discovered what today are described as nation state adversaries who were using the University network as a training ground. His university was the first in Virginia to implement a SIEM, user managed anti-spam technology, and an active countermeasures network based on Tom Liston’s Labrea Tarpit. After that experience, Don took on managing SIEM, conducting employee investigations, and security architecture for a Fortune 500 healthcare firm. That firm was acquired in 2012. He took a security hiatus for a few years when he was an Enterprise Security Architect and then started running the Infrastructure Strategy and Planning team for a Fortune 50 corporation. In 2016, an opportunity to develop an MSSP practice came up with a different boutique consulting firm. After two years, Don left to run the Cyber Range at Regent University, where he is today coaching the next generation of Cyber Defenders. Don is now the lead Countermeasures Principal in a Fortune 50 organization.

Don started working with the SANS Institute in 2002, taking courses, earning certifications, developing Stay Sharp courses during the mid-2000’s, and currently teaches courses at the Community level. He earned the **GIAC Security Expert (GSE #99)** certification in 2014, as was later

vetted as a Cyber Guardian: Blue Team in 2016 (38) by the SANS Institute.